SYSTEM DOCUMENTATION / TECHNICAL HANDOVER

# NADI ASN

## Dokumentasi teknis sistem

Arsitektur, data, API, keamanan
dan panduan operasional untuk tim IT.

**DPMPTSP Prov. Sulawesi Tengah**

Panduan serah terima pengembang & pengelola

**EDISI 2.0 • 5 OKTOBER 2026**

50 halaman | Baseline f03ce2f | Distribusi internal

# Identitas dokumen & batas bukti

Panduan sistem aktif untuk pengembang, DBA, operator dan penerus pengelola.

| Atribut | Nilai |
|---|---|
| Pemilik sistem | DPMPTSP Prov. Sulawesi Tengah |
| Produk | NADI ASN - Navigasi dan Analitik Data Internal ASN |
| Edisi / tanggal | 2.0 / 5 Oktober 2026 |
| Baseline aplikasi | f03ce2f9581af83325d8b9fb2bbc99b45983ab0c |
| Paket / aturan Radar | 0.1.0 / 2026-09-22.1 |
| Produksi | https://nadiasndpmptspsulteng.online |
| Klasifikasi | Internal; tanpa rahasia, identitas pegawai nyata atau database produksi. |

## Tujuan dan acuan

Dokumen menjelaskan arsitektur, kontrak data/API, kontrol akses, deployment, backup dan respons gangguan. Kode aktif menjadi acuan perilaku; bukti bertanggal menjelaskan pemeriksaan yang benar-benar dilakukan. Buku pengguna edisi 2 melengkapi tutorial operasional petugas.

> **Implementasi, bukti dan rencana**
> AKTIF = jalur tersedia pada implementasi. TERVERIFIKASI = diperiksa pada tanggal bukti. BELUM = pekerjaan/validasi tambahan. Pembaruan dokumentasi tidak dianggap sebagai pentest, audit dependency baru, load test atau restore aplikasi penuh.

Edisi ini menggantikan kondisi buku 29 September yang belum memiliki domain dan SMTP. Produksi, sumber utama VPS, backup Drive serta pemantauan aktif sejak 30 September; statistik pengunjung aktif sejak 5 Oktober. PRD/Stage 1 tetap menjadi rancangan awal.

**SUMBER IMPLEMENTASI**
docs/README.md · docs/operations/STATUS_OPERASIONAL.md · docs/VALIDASI.md

# Daftar isi

Klik judul bab atau gunakan bookmark pada pembaca PDF.


| | | |
|---|---|---|
| 02 | Sistem | 04 |
| 03 | Arsitektur | 06 |
| 04 | Kode | 09 |
| 05 | Identitas | 11 |
| 06 | Data | 14 |
| 07 | Aturan bisnis | 22 |
| 08 | API | 29 |
| 09 | Keamanan | 36 |
| 10 | Konfigurasi | 38 |
| 11 | Pengembangan | 39 |
| 12 | Deployment | 41 |
| 13 | Operasi | 44 |
| 14 | Pemeliharaan | 48 |
| 15 | Referensi | 50 |


**Cara membaca sesuai tugas**
Pengembang: arsitektur, kode, data, aturan dan API. Operator: konfigurasi, deployment dan operasi. Penanggung jawab: keamanan, batas layanan dan checklist serah terima. Setiap bab memuat rujukan file sumber.

# Tujuan, lingkup & pengguna

Satu aplikasi kepegawaian dengan pemisahan tegas antara statistik publik dan data individu.

## Tujuan operasional

Menyediakan direktori pegawai yang dapat dipertanggungjawabkan, alur perubahan dengan persetujuan, urutan DUK manual, pemeriksaan administrasi KP/KGB, serta laporan untuk kebutuhan instansi.

| Area | Tanggung jawab |
|---|---|
| Portal publik | Agregat pegawai aktif berdasarkan unit dan jenis pegawai; tidak mengirim identitas individu. |
| Admin Kepegawaian | Membaca data, mengajukan perubahan, impor Excel, mengedit isi DUK dan memperbarui pemeriksaan Radar. |
| Super Admin | Seluruh kegiatan Admin, keputusan usulan, urutan DUK, laporan, unit kerja dan akun Admin. |
| Pengelola teknis | Menjaga runtime, konfigurasi, backup, keamanan, deployment dan pemulihan. Akses SSH/Docker berbeda dari peran akun aplikasi. |

## Batas fungsi

• Tidak ada akun Pimpinan, API penghapusan pegawai, integrasi penggajian, SSO, ataupun sinkronisasi otomatis dengan sistem kepegawaian eksternal.

• Radar adalah pemeriksaan administrasi berdasarkan aturan instansi; hasilnya tidak menerbitkan keputusan kenaikan pangkat/gaji.

• Tautan Google Drive merupakan referensi folder. Aplikasi tidak mengunggah atau mengubah izin dokumen Drive.

> **Definisi rekap aplikasi**
> Total ASN pada NADI ASN = PNS + PPPK Penuh Waktu. PPPK Paruh Waktu direkap terpisah. Ini definisi pengelompokan produk, bukan penetapan status hukum kepegawaian.

**SUMBER IMPLEMENTASI**

routes/api_internal.php · resources/js/apps/internal/InternalApp.vue · app/Modules/Analytics/Services/PublicReleaseReader.php

# Keputusan desain yang berlaku

Revisi kebutuhan setelah PRD/Stage 1 menjadi acuan perilaku aplikasi saat ini.

| Topik | Implementasi aktif |
|---|---|
| DUK | Manual melalui employees.duk_order. Kepala Dinas/sekretaris tidak otomatis dipindahkan oleh algoritme hierarki. |
| Persetujuan | Super Admin boleh menyetujui usulan sendiri; Admin tidak boleh memutuskan. |
| Publik | Agregat langsung dari proyeksi pegawai aktif. Kelompok kecil tetap ditampilkan; rilis publik lama bukan sumber dashboard aktif. |
| Login | NIP 18 digit + password + TOTP. Email hanya untuk pemulihan Super Admin. |
| Data sumber | Masa kerja PDF adalah masa kerja keseluruhan beracuan September 2026; bukan MKG. |
| Penyajian | Tema awal light, tema dark tersimpan di browser; filter jenis jabatan; pilihan 10/30/50/All. |
| Pelaporan | Urutan Excel mengikuti DUK; Unit kerja muncul lebih awal pada PDF; kredit developer tidak dimasukkan dalam laporan. |
| Hosting | Domain HTTPS publik aktif, enam service terisolasi, SMTP, backup terenkripsi dan monitor host aktif. |

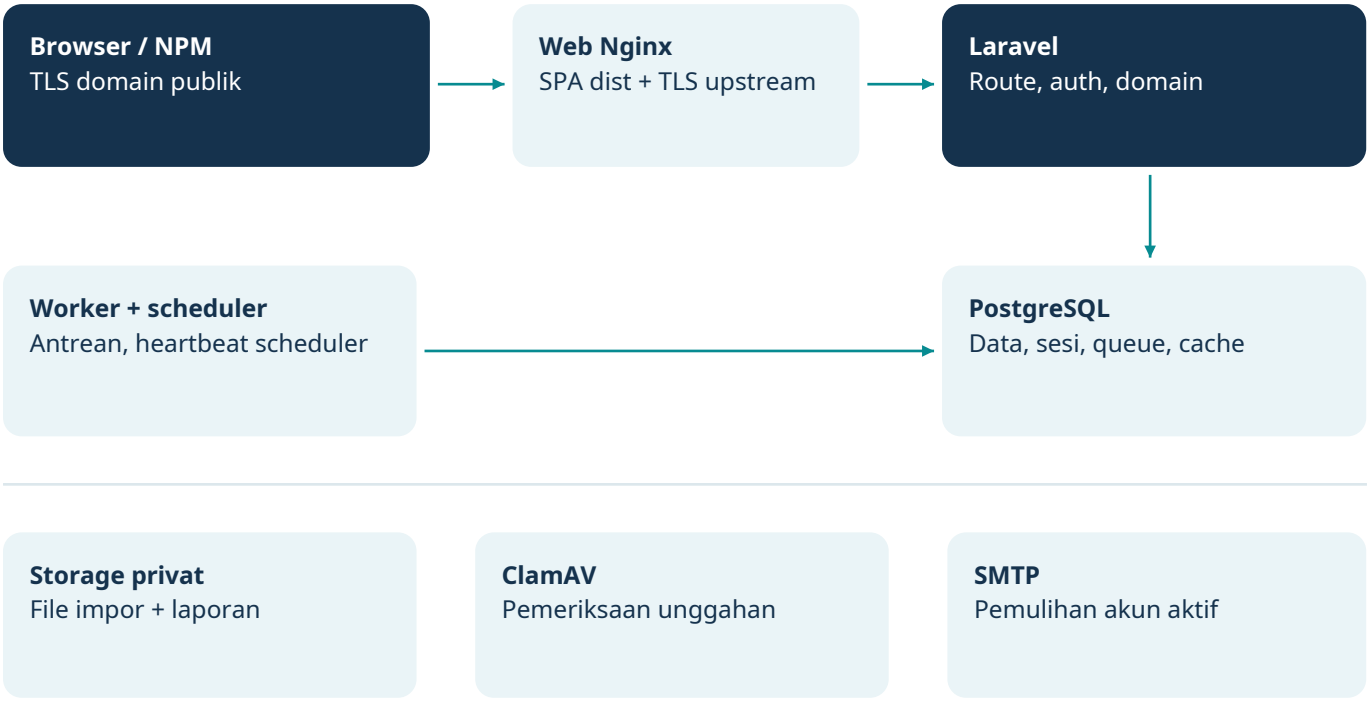
**Dokumen historis bukan spesifikasi tunggal**
PRD, Stage 1, STATUS_IMPLEMENTASI dan VALIDASI memiliki bagian lama. Jika bertentangan, periksa revisi kebutuhan, route aktif, kode dan bukti operasional terbaru. Jangan mengaktifkan kembali fitur lama hanya karena tabelnya masih ada.

Status versi 0.1.0 pada paket adalah identitas paket, bukan tanda bahwa sistem masih menggunakan data simulasi.

**SUMBER IMPLEMENTASI**
docs/STATUS_IMPLEMENTASI.md · docs/VALIDASI.md · docs/operations/VPS_PRIVATE.md · app/Modules/Rules/Services/CalculationGate.php

# Arsitektur aplikasi

Modular monolith: satu backend Laravel, dibagi menurut domain; bukan kumpulan microservice.




Akses dependensi melalui backend/worker; browser tidak terhubung langsung ke DB atau file privat.

## Batas kepercayaan

• Browser dianggap tidak tepercaya. Hak akses, validasi, revisi, kepemilikan berkas dan keputusan tetap diperiksa Laravel.

• Portal hanya memperoleh DTO agregat. Identitas, sumber mentah, password dan secret tidak masuk bundle frontend.

• PostgreSQL dan penyimpanan privat merupakan sumber data runtime. Repository hanya membawa kode, migrasi dan fixture sintetis.

> **Antrean memakai database**
> Tidak ada Redis, RabbitMQ, Elasticsearch, Kubernetes atau layanan object storage yang diwajibkan implementasi ini. Session, cache, lock dan queue menggunakan fasilitas database Laravel.

**SUMBER IMPLEMENTASI**

infra/compose.yaml · routes/web.php · config/session.php · config/cache.php · config/queue.php

# Topologi deployment & jaringan

Web menjadi pintu masuk; service internal tidak dipublikasikan langsung ke host.

| Layanan | Proses / hubungan | Batas RAM |
|---|---|---|
| web | Nginx TLS 8443; host 127.0.0.1:18443 -> 8443. Meneruskan FastCGI ke app:9000. | 128 MiB |
| app | PHP-FPM; koneksi DB, storage privat, SMTP keluar, ClamAV. | 768 MiB |
| worker | queue:work; 3 percobaan, timeout 90 detik, proses diperbarui tiap 3.600 detik. | 768 MiB |
| scheduler | schedule:work; heartbeat satu menit. | 256 MiB |
| db | PostgreSQL 16; hanya jaringan backend; healthcheck pg_isready. | 768 MiB |
| antivirus | ClamAV; TCP 3310 internal, pembaruan signature keluar; healthcheck. | 3 GiB |

Network **backend** bertipe internal. Network **outbound** dipakai web/app/worker/scheduler/antivirus untuk kebutuhan keluar. DB hanya bergabung dengan backend. Tidak ada published port untuk DB, ClamAV atau PHP-FPM.

Nginx Proxy Manager kantor melakukan TLS domain, redirect HTTP/www dan proxy menuju alias **nadi-asn-edge:8443**. Hanya service web ikut jaringan external **proxy** melalui overlay compose.proxy.yaml. App/DB tidak ikut edge. Proxy memverifikasi sertifikat upstream dengan CA privat dan nama localhost; Laravel hanya mempercayai IP NPM aktual.

## Data persisten

Volume Compose: **database**, **private_files**, **app_logs**, **signatures**. Konfigurasi TLS dipasang read-only dari .deploy/tls. Owner DB password hanya dipasang pada container db melalui Docker secret.

> **Kapasitas perlu diukur**
> Batas RAM di Compose adalah limit per service, bukan hasil sizing atau jaminan konsumsi. Total limit sekitar 5,6 GiB di luar OS dan aplikasi kantor lain. Periksa headroom dan OOM sebelum menambah beban.

**SUMBER IMPLEMENTASI**

infra/compose.yaml · infra/nginx/default.conf · infra/docker/clamd.conf · infra/domain/compose.proxy.yaml · infra/domain/nadi-domain-public.conf

# Teknologi & dependensi

Versi berikut menjelaskan baseline proyek; lockfile menentukan versi instalasi yang dapat diulang.

| Lapisan | Teknologi / fungsi |
|---|---|
| Frontend | Vue 3, TypeScript 5.9, Vue Router 4, Vite 7, Tailwind CSS 4. Plus Jakarta Sans lokal dan Lucide untuk ikon. |
| Backend | Laravel 13; composer mensyaratkan PHP ^8.3. Docker memakai PHP 8.4 FPM. |
| Database | PostgreSQL 16; JSONB, transaksi, row lock, trigger dan partial unique index. |
| MFA | pragmarx/google2fa; secret dienkripsi AES-256-CBC memakai kunci khusus TOTP. |
| Excel server | PhpSpreadsheet 5 untuk XLSX yang divalidasi dan ekspor bertipe string. |
| PDF server | Dompdf 3; remote resource dan eksekusi PHP dimatikan. |
| Ekspor browser | ExcelJS, jsPDF dan jspdf-autotable untuk template serta keluaran publik/simulasi. |
| Pengujian | PHPUnit 12 dan Vitest 4; vue-tsc saat build; parser PHP tambahan. |
| Build/hosting | Node 24, Composer 2, Docker Compose, Nginx dan ClamAV. |

Runtime yang tercatat diuji: PHP 8.4.25, Laravel 13.31.0, PostgreSQL 16.15 dan PHPUnit 12.5.35. Angka ini adalah bukti historis proyek, bukan klaim versi terbaru di internet.

> **Reproduksi rilis**
> Gunakan npm ci dan composer install dengan lockfile. Jangan menjalankan pembaruan dependency massal sebagai bagian deployment rutin. Base image Docker memakai digest; pembaruan harus menghasilkan rilis yang diuji kembali.

**SUMBER IMPLEMENTASI**

package.json · package-lock.json · composer.json · composer.lock · infra/docker/Dockerfile · docs/VALIDASI.md

# Peta repository

Mulai dari route dan entry point, lalu ikuti controller, service, model dan pengujiannya.

| Lokasi | Isi dan penggunaan |
|---|---|
| resources/js/ | SPA Vue: apps/public, apps/internal, modules, components, domain, api dan types. |
| resources/css/app.css | Token tema, layout, tabel, responsivitas dan animasi. |
| app/Modules/ | Domain IdentityAccess, Personnel, Governance, Duk, Radar, Imports, SnapshotsReports, Analytics, References, Rules dan Audit. |
| app/Shared/ | Audit append dan canonical JSON/hash. |
| routes/ | web.php: sesi/CSRF; api_public.php; api_internal.php; console.php; provisioning lokal. |
| database/migrations/ | Dua belas migrasi domain/infrastruktur. PostgreSQL diperlukan oleh SQL khususnya. |
| resources/views/ | Template PDF statistik dan email pemulihan. |
| scripts/ | Server/fixture demo, ekstraksi PDF sumber, kalkulator Radar demo dan pemeriksaan sintaks PHP. |
| infra/ | Docker, Compose, Nginx, grant DB dan contoh backup. |
| tests/ | Laravel integration, Vitest unit dan pengujian API demo. |
| docs/ | Keputusan implementasi, panduan pengguna, setup, operasi dan bukti validasi. |

**Jangan disalin ke repository:** .env, .deploy, .runtime, dump DB, token aktivasi, source personnel privat dan berkas storage operasional. Folder runtime Laravel di Git hanya berisi penanda direktori kosong.

Saat menambahkan artefak dokumentasi, tinjau konteks build Docker agar PDF/sumber dokumentasi atau file sementara tidak ikut masuk image runtime tanpa kebutuhan.

**SUMBER IMPLEMENTASI**

.gitignore · .dockerignore · bootstrap/app.php · resources/js/main.ts

# Frontend & kontrak tampilan

Komponen mengambil data melalui API; mode data ditentukan server.

| Bagian | Perilaku |
|---|---|
| Router | /, /tentang, /login, /aktivasi, /internal/:page? dan fallback 404. InternalApp memilih modul berdasarkan halaman. |
| Session store | Reactive session berisi user, ready, demo. loadSession membaca GET /api/session. Tidak memakai JWT di localStorage. |
| API client | fetch same-origin, Accept JSON; X-XSRF-TOKEN berasal dari cookie. FormData tidak dipaksa menjadi JSON. |
| Pagination | allEmployees mengikuti page/per_page backend. Master kemudian memfilter/memaginasi tampilan, termasuk positionType dan 10/30/50/All. |
| Pekerjaan asinkron | waitForResult memeriksa status tiap 1 detik hingga 60 kali. Batas tunggu UI bukan pembatalan job server. |
| Tema | localStorage nadi-theme hanya preferensi tampilan; default light. Tidak memberi hak akses atau mengubah mode data. |
| WebMCP opsional | Dua tool browser untuk membaca agregat dan menerapkan filter publik; tidak memberi akses tulis internal. |

## Prinsip perubahan UI

• Gunakan schema JSON bersama agar kolom Master, DUK, template dan ekspor tidak menyimpang. Perubahan label tetap harus diuji terhadap mapping impor.

• Pertahankan label status berbentuk teks, fokus keyboard, dialog native, scroll tabel dalam kontainer dan dukungan reduced motion.

> **Perhatian skala**
> Pagination API daftar pegawai membatasi respons, tetapi controller saat ini memuat proyeksi seluruh pegawai terlebih dahulu. Tampilan All tidak berarti query database sudah efisien untuk puluhan ribu pegawai.

**SUMBER IMPLEMENTASI**

resources/js/main.ts · resources/js/api/client.ts · resources/js/api/webmcp.ts · resources/js/domain/personnel-schema.json · app/Modules/Personnel/Http/EmployeeController.php

# Autentikasi & siklus sesi

Password yang benar hanya menghasilkan challenge; akses internal mensyaratkan TOTP selesai.

**CSRF**
Ambil cookie

→

**Password**
Challenge 5 menit

→

**TOTP**
Verifikasi 6 digit

→

**Sesi penuh**
Role + versi akun

| Tahap | Detail teknis |
|---|---|
| Login | Cari users.login_name dengan NIP 18 digit, akun aktif, role ADMIN/SUPER_ADMIN, Hash::check. Challenge menyimpan user, security_version dan kedaluwarsa. |
| TOTP | Lock user; validasi versi challenge; decrypt secret memakai NADI_TOTP_KEY; verifyKeyNewer dengan window 1; simpan last_totp_step untuk mencegah replay. |
| Sesi penuh | Auth::login lalu regenerasi session ID. Simpan totp_completed, security_version, absolute_expires_at. |
| Setiap API internal | RequireFullSession memeriksa user aktif, role, TOTP, versi akun dan batas absolut. Gagal: invalidasi sesi, token CSRF baru, HTTP 401. |
| Durasi | Idle default 30 menit melalui SESSION_LIFETIME; maksimum absolut 8 jam. Cookie nadi_session: HttpOnly, SameSite Strict dan Secure pada produksi. |
| Logout | Auth logout, invalidasi session dan regenerasi CSRF. |

**APP_KEY berbeda dari NADI_TOTP_KEY**
APP_KEY melindungi fasilitas enkripsi Laravel/sesi. NADI_TOTP_KEY adalah 32 byte acak dalam base64 untuk secret autentikator. Kehilangan kunci TOTP membuat ciphertext tidak dapat dibaca; mengganti kunci begitu saja bukan prosedur reset.

GET /api/session mengembalikan user ringkas atau null dan demo:false. Informasi ini untuk UI; otorisasi tetap dievaluasi ulang pada tiap endpoint internal.

**SUMBER IMPLEMENTASI**
app/Modules/IdentityAccess/Http/AuthController.php · app/Modules/IdentityAccess/Middleware/RequireFullSession.php · config/session.php

# Akun, aktivasi & pemulihan

Tautan aktivasi dan tautan pemulihan memakai alur akhir yang sama, tetapi dampak penerbitannya berbeda.

| Alur | Perilaku saat ini |
|---|---|
| Akun Admin | Super Admin memilih pegawai aktif. employee_id dan login_name harus unik; role payload dilarang dan server menetapkan ADMIN. |
| Reset Admin | Akun langsung nonaktif; security_version bertambah, password acak dan secret TOTP baru. Tautan berlaku 24 jam, hash SHA-256 disimpan. |
| Pemulihan Super Admin | Cari recovery_email. Token 32 byte acak -> 64 karakter hex; secret baru disimpan terpisah. Berlaku 30 menit; akun lama tetap bekerja sampai aktivasi berhasil. |
| Aktivasi | URL /aktivasi#token. Client mengirim X-Activation-Token; password minimal 12, konfirmasi password dan OTP wajib. Token dihapus setelah berhasil. |
| Penonaktifan | Admin nonaktif, versi keamanan bertambah dan tautan aktivasi dicabut. Data pegawai tidak dihapus. |
| Proteksi Super Admin | UI akun tidak membuat, mereset atau menonaktifkan Super Admin. Akun pertama melalui provisioning operator. |

## Batas dan implikasi

• QR enrollment, recovery codes dan reauthentication khusus belum tersedia. Secret ditambahkan manual ke autentikator.

• Perubahan NIP/nama di Master tidak otomatis menyinkronkan login_name/nama akun. Perlakukan koreksi identitas login sebagai pekerjaan pengelola yang diverifikasi.

> **Pengiriman email produksi aktif**
> RecoveryController mengirim email sinkron di dalam transaksi. SMTP gagal -> token baru di-rollback dan respons 503. Keberhasilan mail fake di tes bukan bukti pengiriman SMTP nyata.

**SUMBER IMPLEMENTASI**

app/Modules/IdentityAccess/Http/AccountController.php · app/Modules/IdentityAccess/Http/ActivationController.php · app/Modules/IdentityAccess/Http/RecoveryController.php

# Matriks otorisasi backend

P = publik, A = Admin Kepegawaian, S = Super Admin. Semua mutasi membutuhkan CSRF.

| Operasi | P | A | S |
|---|---|---|---|
| Statistik/daftar unit publik | Ya | Ya | Ya |
| Data individu, dashboard, DUK, Radar | - | Ya | Ya |
| Mengajukan / batch perubahan | - | Ya | Ya |
| Memutuskan usulan | - | - | Ya |
| Mengubah urutan DUK | - | - | Ya |
| Impor: unggah/validasi/konfirmasi | - | Milik sendiri | Milik sendiri |
| Detail batch milik Admin lain | - | - | Baca saja |
| Ekspor internal / unduhan | - | - | Milik sendiri + versi akun |
| Baca audit / penjelasan rules | - | Ya | Ya |
| Kelola unit dan akun Admin | - | - | Ya |
| Edit pemeriksaan KP/KGB | - | Ya | Ya |

## Pemeriksaan berlapis

Middleware full-session menolak sesi parsial dan akun yang tidak sah. Controller/service memeriksa peran dan kepemilikan; constraint, transaction dan trigger menjaga integritas DB. Tautan langsung ke halaman atau menyembunyikan tombol tidak menggantikan kontrol ini.

> **Tidak ada pembatasan Admin per unit**
> Role ADMIN saat ini boleh membaca dan mengajukan perubahan lintas unit. Jika organisasi membutuhkan pembatasan per unit, tambahkan policy dan tes backend; filter dropdown bukan kontrol akses.

Daftar audit hanya 100 kejadian terakhir; daftar usulan 100, daftar impor milik sendiri 100, riwayat ekspor 50. Batas ini perlu diperhatikan ketika menelusuri kejadian lama.

**SUMBER IMPLEMENTASI**

routes/api_internal.php · app/Modules/Imports/Services/ImportService.php · app/Modules/SnapshotsReports/Http/ExportController.php

# Model data & hubungan inti

UUID menjadi identitas mayoritas entitas; relasi berikut merangkum domain aktif.

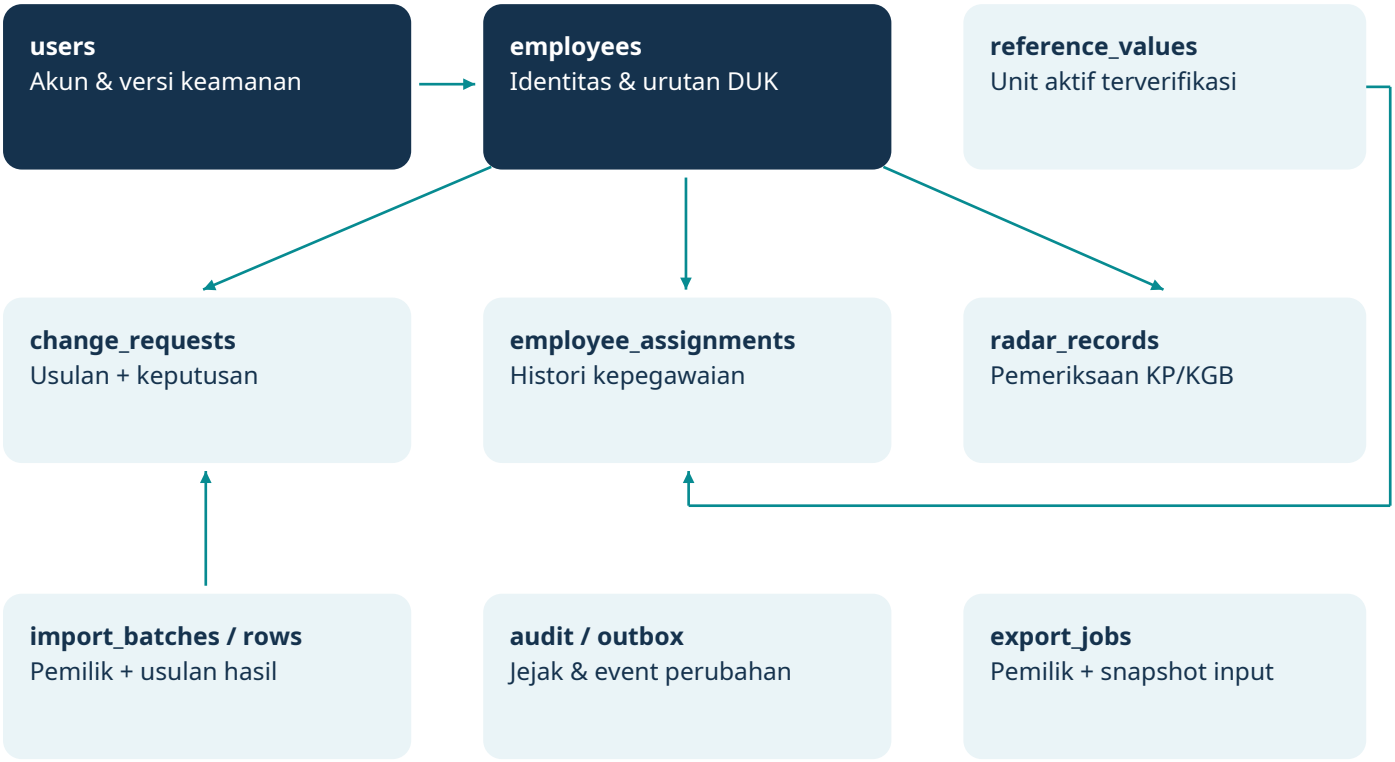



Diagram hubungan logis inti; FK tambahan ke users dan detail kardinalitas dijelaskan pada kamus data.

## Kaidah hubungan

• Satu employee dapat memiliki banyak assignment dan change request; users.employee_id bersifat nullable dan unik.

• Unit kerja disimpan di reference_values dengan kind=unit; assignment menyimpan unit_id serta label historis unit.

• Radar memakai primary key gabungan employee_id + kind. Kolom updated_by menunjuk user pemeriksa.

• Import row dapat menunjuk change_request yang dihasilkan saat konfirmasi. ExportJob menyimpan pemilik dan salinan parameter/data laporan.

> **Bukan model histori bitemporal penuh**
> Identitas di employees diperbarui langsung setelah persetujuan. Histori assignment tersedia, tetapi tidak seluruh atribut identitas dapat direkonstruksi secara point-in-time. Audit/changes menyimpan bukti perubahan, bukan pengganti resolver histori lengkap.

**SUMBER IMPLEMENTASI**

database/migrations/ · app/Modules/Personnel/Models/Employee.php · app/Modules/Governance/Services/ChangeService.php

# Kamus data: pegawai & unit

Nama kolom database memakai snake_case; DTO frontend memakai camelCase.

| Tabel / kolom | Tipe dan makna |
|---|---|
| employees.id; nip | UUID PK; varchar(18) unik + CHECK 18 digit. NIP selalu teks. |
| name; gender | varchar(200); varchar(20), CHECK Perempuan/Laki-laki. |
| birth_place; birth_date | varchar(100) nullable; date nullable. Dasar perhitungan usia. |
| education; institution; graduation_date | varchar(30); text nullable; date nullable. Tingkat, institusi/nama pendidikan dan tanggal lulus. |
| drive_url; revision | text nullable; bigint default 1. Revisi kontrol konkurensi. |
| source_order; duk_order | integer nullable; integer unsigned secara deklarasi Laravel, nullable dan berindeks. Urutan sumber terpisah dari urutan aktif. |
| age_at_reference; source_payload; source_issues | integer nullable; JSONB nullable; JSONB nullable. Arsip sumber/masalah; usia DTO dihitung ulang. |
| created_at; updated_at | Timestamp with time zone. |
| reference_values | id UUID PK; kind varchar(30), code varchar(50), label varchar(200); verified/active boolean; metadata JSONB nullable; timestamps. Unique(kind,code). |

## Unit kerja dan rename

Proyeksi membaca label dari relasi unit_id, dengan fallback label assignment. Rename menghubungkan assignment lama tanpa unit_id ke referensi yang sama. Daftar urutan tampilan berada pada unit-order.json dan diurutkan konsisten oleh PHP/TypeScript.

> **Catatan penonaktifan unit**
> Pemeriksaan occupied menelusuri seluruh assignment berstatus OFFICIAL, tidak hanya assignment terbaru. Riwayat OFFICIAL lama dapat tetap menghalangi penonaktifan meski pegawai sudah pindah. Jangan menghapus histori; evaluasi aturan/proyeksi jika kondisi ini muncul.

**SUMBER IMPLEMENTASI**

database/migrations/2026_09_11_000002_create_personnel_and_governance.php · database/migrations/2026_09_14_000005_personnel_directory_update.php · app/Modules/References/Http/UnitController.php

# Kamus data: penugasan

employee_assignments menyimpan kondisi jabatan dan kepegawaian yang disahkan.

| Kolom | Tipe / aturan |
|---|---|
| id; employee_id; approved_by | UUID PK; FK employees; FK users. Relasi utama restrict-on-delete. |
| type; status; record_status | varchar(30), varchar(30), varchar(20). Jenis pegawai, status kepegawaian dan OFFICIAL/SUPERSEDED. |
| unit; unit_id | varchar(150); FK reference_values nullable. |
| position; position_type; grade | varchar(200), varchar(50), varchar(20). |
| effective_date | date wajib. Tanggal berlakunya record histori, ditetapkan hari persetujuan. |
| position_tmt; rank_tmt; rank_name | date nullable; date nullable; varchar(200) nullable. |
| service_years; service_months; service_reference | integer nullable; integer nullable; varchar(7), default 2026-09. |
| contract_start; contract_end | date nullable. CHECK: tanggal akhir memerlukan tanggal mulai dan tidak boleh lebih awal. |
| duk_position_level; training_level; training_date | varchar(60), varchar(40), date nullable. Sisa dukungan hierarki DUK lama; tidak mengurutkan DUK manual. |
| created_at; updated_at | Timestamp with time zone. |

## Indeks dan pemilihan record

Indeks employee_id/record_status/effective_date membantu pemilihan assignment. Partial unique index membatasi satu OFFICIAL per pegawai per effective_date. Proyeksi memilih OFFICIAL terakhir dengan effective_date <= tanggal acuan.

> **Tiga tanggal yang berbeda**
> DTO effectiveDate adalah TMT jabatan dari position_tmt. Kolom DB effective_date adalah tanggal penerapan histori. rank_tmt adalah TMT pangkat untuk Radar. Jangan memetakan ketiganya ke satu tanggal ketika membuat integrasi.

**SUMBER IMPLEMENTASI**

database/migrations/2026_09_11_000002_create_personnel_and_governance.php · database/migrations/2026_09_14_000006_separate_position_date.php · app/Modules/Personnel/Services/EmployeeProjection.php

# Kamus data: identitas akses

Secret tidak boleh ditampilkan pada log, dump publik, tiket atau tangkapan layar dokumentasi.

| Tabel | Kolom penting dan invariannya |
|---|---|
| users | id UUID; name; email nullable/unique; login_name nullable/unique; employee_id nullable/unique FK; password; role; is_active; security_version; totp_secret; last_totp_step; remember_token; recovery_email; timestampsTz. |
| account_activations | user_id PK/FK; token_hash varchar(64); expires_at timestamptz. Satu tautan terakhir per akun. |
| account_recoveries | user_id PK/FK; token_hash unique; totp_secret terenkripsi; security_version bigint; expires_at dan created_at timestamptz. |
| sessions | id string PK; user_id nullable FK; ip_address; user_agent; payload; last_activity integer berindeks. |

## Hash, enkripsi dan revokasi

• User model memakai cast password hashed dan Hash::check. Password tidak disimpan dalam teks asli; algoritme mengikuti hasher Laravel yang aktif.

• totp_secret dienkripsi memakai kunci khusus, sedangkan token aktivasi/pemulihan disimpan sebagai SHA-256. Token mentah hanya tersedia saat diterbitkan/dikirim.

• security_version dibandingkan pada sesi, challenge TOTP, pemulihan dan ekspor. Kenaikan versi membatalkan kewenangan lama tanpa mengandalkan browser menutup halaman.

> **Provisioning pertama memiliki langkah lanjutan**
> nadi:create-admin membuat akun dengan NIP, password dan secret dari proses enrollment, tetapi tidak mengisi recovery_email atau employee_id. Kaitan pegawai dan email pemulihan perlu ditetapkan pengelola tepercaya; jangan menganggap email biasa otomatis menjadi email pemulihan.

**SUMBER IMPLEMENTASI**

app/Modules/IdentityAccess/Models/User.php · database/migrations/2026_09_15_000008_manual_duk_and_accounts.php · database/migrations/2026_09_16_000009_super_admin_recovery.php · routes/console.php

# Kamus data: perubahan & audit

Semua keputusan yang diterapkan harus dapat ditelusuri ke pembuat, pemeriksa dan alasan.

| Tabel | Kolom / fungsi |
|---|---|
| change_requests | id UUID; employee_id nullable; maker_id; checker_id nullable; status default PENDING; before JSONB; changes JSONB; base_revision bigint; content_hash SHA-256; reason; decision_reason; applied_at; timestampsTz. |
| audit_events | id UUID; actor_id FK; actor_name; action; subject; metadata JSONB; created_at. Indeks actor_id/created_at. |
| outbox_events | id UUID; kind; aggregate_id UUID; payload JSONB; created_at; processed_at nullable berindeks. |
| radar_records | PK(employee_id UUID,kind varchar(3)); data JSONB; revision integer; employee_revision integer; updated_by FK users; created_at/updated_at. |

## Integritas dan batasnya

• content_hash dihitung dari canonical JSON: key object diurutkan; urutan array dipertahankan; SHA-256 dihitung atas representasi deterministik.

• Trigger nadi_prevent_mutation menolak UPDATE/DELETE audit. Role runtime juga tidak diberi hak mengubah/menghapus audit atau TRUNCATE.

• Trigger check_self_approval mengizinkan maker=checker hanya jika role checker adalah SUPER_ADMIN. Validasi akun aktif tetap di aplikasi.

• Outbox PERSONNEL_CHANGED ditulis dalam transaksi persetujuan. Consumer outbox belum tersedia; jangan menganggap notifikasi/sinkronisasi sudah berjalan.

> **Audit bukan hash-chain bertanda tangan**
> Canonical hash digunakan pada objek tertentu, bukan rantai kriptografis seluruh audit. Operator DB owner tetap merupakan pihak berprivilege tinggi; pisahkan pengelolaan owner, akses runtime dan backup.

**SUMBER IMPLEMENTASI**

app/Shared/CanonicalJson.php · app/Shared/Audit.php · database/migrations/2026_09_15_000008_manual_duk_and_accounts.php · database/migrations/2026_09_22_000011_create_radar_records.php

# Kamus data: impor & laporan

Berkas disimpan pada disk local privat; database menyimpan metadata, preview dan status.

| Tabel | Kolom penting |
|---|---|
| import_batches | id; maker_id; filename; file_path; checksum; status; mapping JSONB; headers JSONB; row_count; preview_hash; error_message; duplicate_of nullable UUID; confirmed_at; expires_at; timestampsTz. |
| import_rows | id; batch_id FK; row_number; status; source JSONB; diff JSONB; errors JSONB; change_request_id nullable FK; timestampsTz. Unique(batch_id,row_number). |
| export_jobs | id; owner_id FK; status; format; kind; file_path nullable; parameters JSONB; expires_at nullable; timestampsTz. |

**File privat**
Checksum bytes
→
**Preview**
Hash isi/diff
→
**Usulan**
Revisi pegawai
→
**Hasil**
Audit + metadata

## Masa simpan bukan penghapusan otomatis

expires_at impor diisi berdasarkan NADI_IMPORT_RETENTION_DAYS, default 14 hari. Namun authorize/confirm saat ini tidak memeriksa expiry; belum ada purge terjadwal. Jangan menyebut impor otomatis terblokir atau terhapus setelah 14 hari.

Laporan READY memperoleh expiry tujuh hari dari waktu render. Endpoint unduh memeriksa expiry dan keberadaan berkas. Penghapusan file fisik setelah expiry belum dijadwalkan; pemantauan kapasitas dan kebijakan retensi tetap perlu dibuat.

> **Pisahkan metadata dan file**
> Backup DB saja tidak memulihkan berkas imports/exports di volume private_files. Sebaliknya, menyalin file tanpa metadata DB tidak memulihkan kepemilikan dan status unduh.

**SUMBER IMPLEMENTASI**

database/migrations/2026_09_11_000003_create_rules_imports_and_publication.php · database/migrations/2026_09_12_000004_extend_import_workflow.php · app/Modules/Imports/Services/ImportService.php

# Statistik pengunjung dan penyimpanan

Tujuh metrik website yang tidak mengidentifikasi pegawai atau akun.

**Browser**
Cookie UUID acak

→

**Heartbeat**
Terlihat setiap menit

→

**Deduplikasi**
HMAC harian

→

**Agregat**
Jumlah per tanggal

| Tabel | Struktur dan retensi |
|---|---|
| visitor_daily_totals | visit_date date PK; visitors bigint. Agregat kumulatif tanpa identifier browser. Tetap disimpan untuk semua periode. |
| visitor_presences | PK visit_date + daily_hash char(64); online_hash char(64); last_seen timestamptz berindeks. HMAC memakai APP_KEY. Prune hourly mempertahankan hari ini dan kemarin. |

## Definisi waktu dan angka

WITA Asia/Makassar. Hari ini/kemarin: browser unik per tanggal. Minggu mulai Senin; bulan mulai tanggal 1; tahun mulai 1 Januari. Periode dan total adalah penjumlahan unik harian, bukan individu unik sepanjang periode. Online adalah distinct online_hash yang aktif dalam lima menit, termasuk deduplikasi lintas tengah malam.

## Konsistensi dan privasi

insertOrIgnore presence dan atomic UPSERT totals dalam transaksi membuat tab bersamaan tidak menggandakan harian. Reload memperbarui last_seen. Tabel tidak menyimpan IP, User-Agent, akun, nama, NIP atau URL. GET hanya membaca dan tidak menambah jumlah; bot umum dilewati berdasarkan User-Agent.

**Sumber angka**
Produksi mulai 5 Oktober 2026 tanpa rekonstruksi sebelumnya. Cookie terhapus/browser lain dapat dihitung baru; online merupakan perkiraan. Presence dalam backup mengikuti retensi backup, walau tabel aktif telah dipangkas. TrackingSince adalah tanggal pertama aktivitas tercatat.

**SUMBER IMPLEMENTASI**
database/migrations/2026_10_01_000012_create_visitor_statistics.php · app/Modules/Analytics/Services/VisitorStatistics.php · routes/console.php

# Infrastruktur data & komponen lama

Katalog ini mencegah salah tafsir bahwa semua tabel memiliki menu atau API aktif.

| Tabel / komponen | Status dan kegunaan |
|---|---|
| jobs; failed_jobs | Queue database Laravel. jobs menyimpan payload/reservasi/attempt; failed_jobs menyimpan exception kegagalan. Log/payload tetap data internal. |
| cache; cache_locks | Cache key/value/expiry dan distributed lock. Digunakan juga rate limiter, restart worker dan heartbeat scheduler. |
| migrations | Catatan migrasi Laravel; runtime hanya SELECT. |
| rulesets | Skema versi aturan, parameters JSONB, hash, maker/checker, status dan effective_date. UI aktif hanya penjelasan rules; kalkulator Radar menggunakan konstanta kode. |
| duk_candidates | Payload kandidat DUK hierarki lama dengan ruleset/as_of/hash/maker; immutable. Bukan sumber DUK manual aktif. |
| published_snapshots | Payload publikasi historis, ruleset, template, pembuat/penerbit, hash dan duk_candidate_id opsional. Immutable. |
| public_releases | safe_payload historis, data_revision, policy_version, approver, expiry dan hash. Bukan sumber portal aktif. |
| notifications | Skema user/kind/title/payload/read_at tersedia, belum ada alur notifikasi lengkap melalui API aktif. |

**Jangan membuka route lama tanpa review**
DukController, DukRanking dan cabang renderer kind=duk masih ada. routes/api_internal.php aktif memakai ManualDukController; POST exports hanya menerima employees/statistics. Constraint publisher!=maker pada tabel publikasi lama tidak sama dengan kebijakan self-approval change request.

Dua belas migrasi tersusun dari 000001 sampai 000012. Beberapa down() sengaja menolak rollback karena membawa histori/kebijakan. Gunakan migrasi lanjutan yang ditinjau; jangan mengandalkan migrate:rollback untuk memulihkan produksi.

**SUMBER IMPLEMENTASI**
database/migrations/ · routes/api_internal.php · app/Modules/Duk/Http/DukController.php · app/Modules/SnapshotsReports/Jobs/RenderExport.php

# Proyeksi data, waktu & kualitas

Nilai tampilan dapat berubah mengikuti tanggal tanpa menulis ulang semua record database.

## Masa kerja keseluruhan

```
selisih_bulan = max(0, (tahun_kini - tahun_acuan) * 12
                     + bulan_kini - bulan_acuan)
total_bulan = tahun_sumber * 12 + bulan_sumber + selisih_bulan
tahun_tampil = total_bulan // 12
bulan_tampil = total_bulan % 12
```

PersonnelClock memakai service_reference YYYY-MM, dengan acuan awal 2026-09. Jika bulan sumber di luar 0-11, anomali dipertahankan agar diperiksa petugas. Data acuan tidak digeser setiap kali dibaca. Saat masa kerja diubah, referensi baru default bulan pengajuan.

| Contoh | Nilai |
|---|---|
| September 2026 | 13 tahun 1 bulan |
| Oktober 2026 | 13 tahun 2 bulan |
| Juli 2029 | 15 tahun 11 bulan |

## Usia dan kelengkapan

Usia dihitung dari birth_date ke tanggal acuan, dibulatkan ke tahun penuh; tanggal lahir kosong/di masa depan menghasilkan null. APP_TIMEZONE adalah Asia/Makassar. Halaman yang tetap terbuka perlu dimuat ulang agar proyeksi baru terlihat.

Kelengkapan = persentase isian relevan yang tidak null/kosong/“-”. Schema 18 kolom, usia dikecualikan; PPPK Paruh Waktu juga mengecualikan rankName, serviceYears, serviceMonths. Angka 0 sah. Skor tidak menjamin kebenaran dokumen.

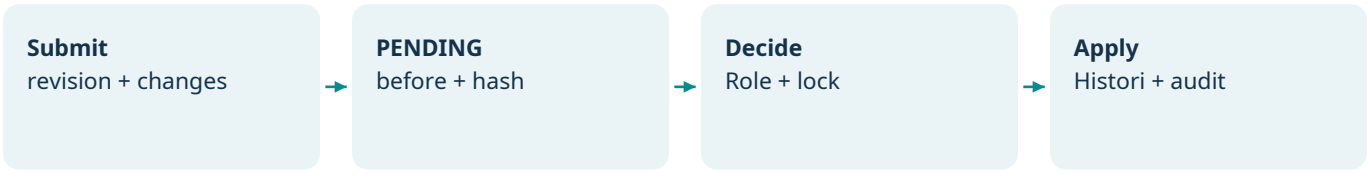
> **Batas histori waktu**
> asOf pada proyeksi memilih assignment menurut tanggal, tetapi identitas employees tetap nilai terbaru. Fungsi service tidak menghitung mundur sebelum bulan acuan. Hindari menyebut keluaran ini arsip historis penuh.

**SUMBER IMPLEMENTASI**

app/Modules/Personnel/Services/PersonnelClock.php · app/Modules/Personnel/Services/EmployeeProjection.php · resources/js/domain/personnel-schema.json

# Transaksi perubahan pegawai

Data resmi hanya berubah ketika proposal APPROVED berhasil diterapkan.




## Saat usulan dikirim

• Lock employee jika ada; base revision harus sama. Perubahan umur otomatis dibuang. Tolak field di luar allowlist; validasi kandidat gabungan before + changes.

• Periksa NIP unik, enum, tanggal, unit aktif terverifikasi dan URL Drive HTTPS yang diizinkan. Simpan proposal PENDING, canonical content_hash dan alasan.

## Saat diputuskan

• Hanya Super Admin. Lock proposal, pastikan masih PENDING dan hash cocok. APPROVED memeriksa revisi employee dan validasi kandidat sekali lagi.

• TMT jabatan masa depan ditolak saat penerapan. Update identitas, naikkan revision; assignment OFFICIAL pada hari yang sama menjadi SUPERSEDED, lalu buat assignment OFFICIAL baru.

• Simpan status APPROVED/REJECTED, checker, alasan, applied_at jika disetujui, audit dan outbox dalam transaksi. Kegagalan membatalkan penerapan parsial.

> **Penanganan 409**
> Muat ulang, bandingkan data terbaru dan susun usulan baru. Jangan menimpa revision/hash untuk memaksa lewat. Proposal yang ditolak tidak diedit langsung; perbaikan diajukan lagi.

Batch edit isi DUK dibatasi 500 baris dan dibungkus transaksi. Bila satu baris konflik, pengajuan batch dibatalkan seluruhnya. Pembuatan pegawai memakai employeeId kosong dengan nilai wajib lengkap.

**SUMBER IMPLEMENTASI**
app/Modules/Governance/Http/ChangeController.php · app/Modules/Governance/Services/ChangeService.php

# DUK manual & unit organisasi

Urutan pegawai dan urutan unit adalah dua konsep yang berbeda.

## Kontrak urutan DUK

GET /api/duk menghasilkan rows, daftar seluruh employee ID dalam order, dan hash canonical dari order. Penyimpanan Super Admin harus mengirim seluruh ID tepat satu kali, hash awal, alasan serta rows perubahan isi jika ada.




ManualDukController menggunakan LOCK TABLE employees IN SHARE ROW EXCLUSIVE MODE. Hash yang berbeda menghasilkan 409. Jika set ID tidak sama, respons 422. Urutan disimpan sebagai duk_order 1..N dan audit before/after; perubahan sel tetap berupa proposal.

## Perilaku filter

Panah menaikkan/menurunkan menukar pegawai dengan tetangga pada hasil filter, termasuk lintas halaman. Pegawai di luar filter tetap pada posisi globalnya. Nomor urut terlihat dapat melompat; ekspor mengikuti urutan global tersimpan.

## Urutan unit

Kepala Dinas, Sekretaris, TIM 1-7, lalu Sekretariat Kepegawaian dan Umum, Keuangan dan Aset, Program. Nama/urutan acuan berada di resources/js/domain/unit-order.json; PHP UnitOrder dan frontend memakainya. Unit tambahan diurutkan setelah acuan.

> **Implikasi integrasi**
> Jangan menafsirkan source_order sebagai nomor DUK aktif. Pegawai baru yang belum diberi duk_order ditempatkan sesudah yang sudah diurutkan. Mengubah label unit tidak mengubah urutan pegawai.

**SUMBER IMPLEMENTASI**

app/Modules/Duk/Http/ManualDukController.php · app/Modules/Personnel/Models/Employee.php · resources/js/modules/duk/DukPage.vue · resources/js/domain/unit-order.json

# Pipeline impor XLSX

Upload, validasi preview dan konfirmasi adalah tahap berbeda dengan hak pemilik.

**UPLOADED**
Scan + staging

→

**VALIDATING**
Worker

→

**PREVIEW**
VALID / INVALID

→

**CONFIRMED**
Usulan dibuat

| Tahap | Jaminan / batas |
|---|---|
| Upload | XLSX 5 MiB; ClamAV sebelum parsing; satu worksheet, 1.000 baris data, 50 kolom; 2.000 entry ZIP, 25 MiB terurai. File bernama acak disimpan privat. |
| Mapping | Field tujuan allowlist; NIP wajib dipetakan; nama header harus ada dan satu kolom tidak dipakai dua field. |
| Validasi | Worker membaca staging, menolak formula/NIP numerik/duplikat; mencari NIP untuk update atau insert; sel kosong tidak menghapus nilai existing. |
| Preview | Baris VALID, INVALID atau UNCHANGED; preview_hash mencakup status/diff. Error tersedia per baris. |
| Konfirmasi | Hash harus cocok; unggahan identik butuh confirmDuplicate. Baris VALID menjadi proposal; konflik revisi membatalkan seluruh konfirmasi. |
| Ulang konfirmasi | Batch CONFIRMED dengan hash sama mengembalikan jumlah proposal sebelumnya; tidak menggandakan usulan. |

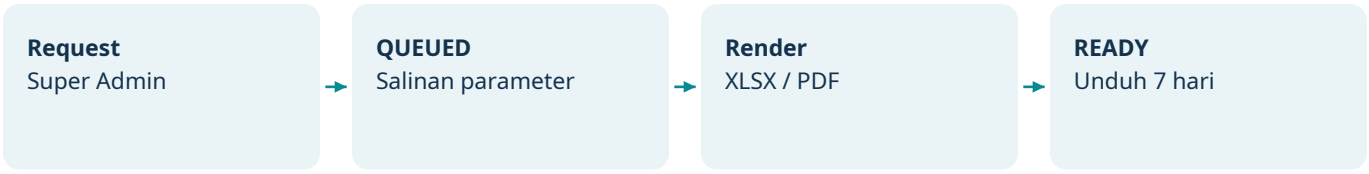
ValidateImport memiliki tries=3 dan timeout=90. Setelah gagal permanen, batch berubah FAILED dengan pesan generik. Konfirmasi sukses tidak berarti perubahan pegawai telah disetujui.

**Template dan status tambahan**
Template UI berisi 17 isian, tidak termasuk usia otomatis. Backend masih menerima beberapa field lama/opsional dalam allowlist untuk kompatibilitas; itu bukan alasan menambahkan kolom sumber kembali ke UI. Tidak ada rollback kompensasi massal setelah proposal disetujui.

**SUMBER IMPLEMENTASI**
app/Modules/Imports/Services/ImportService.php · app/Modules/Imports/Jobs/ValidateImport.php · app/Modules/Imports/Services/UploadScanner.php

# Pipeline laporan & statistik

Input laporan dibekukan ketika permintaan dibuat, bukan ketika worker mulai merender.




## Laporan internal

kind=employees menghasilkan XLSX, default pegawai Aktif kecuali allStatuses. Filter unit/type/positionType/status/search/quality diterapkan; baris mengikuti DUK. kind=statistics menghasilkan PDF agregat per unit; controller statistik saat ini meneruskan unit saja, bukan seluruh filter ekspor pegawai.

parameters menyimpan actor, securityVersion, filter dan rows atau statistics. XLSX memakai tipe string eksplisit untuk semua nilai, mempertahankan NIP dan mencegah formula. PDF memakai Blade escaped, remote resource false dan isPhpEnabled false.

## Unduh dan daftar riwayat

Pemilik, role Super Admin, security_version, status READY, expiry dan keberadaan file diperiksa. Permintaan dan unduhan masuk audit. Renderer dapat diulang dan berhenti jika job sudah READY. Gagal permanen menjadi FAILED.

## Statistik publik

PublicReleaseReader membaca proyeksi aktif lalu membentuk DTO agregat. Default grafik mengikuti kelompok ASN; filter Paruh Waktu membuat grafik kelompok itu, sementara total ASN tetap nol. Tidak ada nama/NIP/tanggal lahir/source dalam DTO publik.

> **Jangan tertukar dengan rilis lama**
> NADI_PUBLIC_RELEASE_ENABLED dan tabel public_releases tidak mengendalikan dashboard aktif. Nama PublicReleaseReader bersifat historis; kelas ini sekarang membaca agregat langsung. Angka tepat kelompok kecil tetap berpotensi dikaitkan dengan pengetahuan eksternal.

**SUMBER IMPLEMENTASI**

app/Modules/SnapshotsReports/Http/ExportController.php · app/Modules/SnapshotsReports/Jobs/RenderExport.php · app/Modules/Analytics/Services/PublicReleaseReader.php

# Mesin aturan KP & KGB

Kalkulator PHP menjadi acuan pemeriksaan administrasi versi 2026-09-22.1.

| Jalur | Aturan utama yang diterapkan |
|---|---|
| KP Pelaksana | Minimal 4 tahun dari rankTmt pada target; pendidikan diakui dan tidak melampaui batas; ujian dinas/pembebasan untuk transisi relevan; kinerja dua tahun minimal Baik. |
| KP Fungsional | Minimal 2 tahun; jenjang Ahli dibaca dari nama jabatan dan sesuai golongan tujuan; AK/PAK dan verifikasi fungsional; kinerja minimal Baik. |
| KP Struktural | Target ditetapkan pengelola; rentang pangkat, jalur dan riwayat pelantikan diverifikasi. Tidak menggunakan rumus umum empat tahun. |
| KGB | lastKgbTmt + 2 tahun (tanpa overflow tanggal). lastKgbDate terpisah sebagai tanggal SK. Kinerja dua tahun minimal Cukup; dokumen diverifikasi. |
| Batas pendidikan KP | SD II/a; SMP II/c; SMA/SMK/D1/D2 III/b; D3 III/c; S1/D4 III/d; S2 IV/a; S3 IV/b. |
| AK fungsional | Golongan terakhir III/a-b: 50; III/c-d: 100; IV/a-c: 150; IV/d-e: 200. Tambahan kumulatif III/b:100, III/d:200, IV/c:450. |

KP memakai tanggal target 1 sejak Oktober 2025. Perkiraan otomatis dibulatkan ke periode yang memenuhi masa pangkat dan belum melewati tenggat baseline. Target yang telah diperiksa dibekukan saat save agar siklus tidak bergeser diam-diam.

> **Cakupan terbatas**
> Hanya PNS aktif. Perhitungan fungsional berfokus pada jenjang Ahli; jabatan yang tidak dikenali membutuhkan penanganan aturan, bukan menebak jenjang. Ruleset ini mendokumentasikan implementasi instansi; validasi kebijakan baru harus disertai perubahan kode dan tes.

**SUMBER IMPLEMENTASI**

app/Modules/Radar/Services/RadarCalculator.php · NADI-ASN-Rules-KP dan KGB.md · docs/user/RADAR.md

# Radar: data, revisi & pengingat

Kesiapan administratif berbeda dari status proses usulan.

| Kelompok data JSON | Field |
|---|---|
| Waktu | lastKgbDate, lastKgbTmt, targetDate, deadline, correctionDeadline. |
| Kinerja dan AK | performance1/2, performanceYear1/2, credit, cumulativeCredit. |
| Verifikasi | documentsVerified, educationRecognized, examVerified, functionalVerified, managerialVerified. |
| Referensi | documentReference, appointmentReference, pakReference, scheduleReference. |
| Proses | process, processNote, reason; employeeRevision disisipkan dari Master. |

Simpan memakai revision Radar dan employeeRevision. Server mengunci employee dan record Radar; mismatch menghasilkan 409. data disaring allowlist, audit menyimpan before/after serta versi aturan. Perubahan Radar berlaku langsung tanpa antrean persetujuan Master.

## Keluaran kalkulator

status, checks (pass/fail/missing), reasons, targetDate, earliestDate, nextGrade, level, creditNeeded, cumulativeNeeded, reminderDate, reminderActive, submissionOpen, deadline, performanceYears, asOf dan version.

Fail memiliki prioritas terhadap missing: Belum memenuhi -> Data belum lengkap -> Siap diusulkan. Tahun kinerja harus target-2 dan target-1. Perubahan revision Master menambahkan kebutuhan verifikasi ulang.

> **Pengingat bukan pengirim notifikasi**
> KP baseline berkas 16 bulan M-2 sampai 15 bulan M-1; tenggat khusus memerlukan surat acuan. Pengingat mulai target minus dua bulan dan berhenti pada Keputusan terbit/Ditolak. Evaluasi saat data dibaca; tidak ada pengiriman email/WhatsApp otomatis. Status keputusan tidak mengubah Master.

**SUMBER IMPLEMENTASI**

app/Modules/Radar/Http/RadarController.php · app/Modules/Radar/Services/RadarCalculator.php · app/Modules/Analytics/Http/DashboardController.php

# Konvensi API & respons error

Base URL /api. Endpoint browser memakai session cookie Laravel dan CSRF, bukan bearer token.

| Aspek | Kontrak |
|---|---|
| Transport | JSON UTF-8 untuk request/response, kecuali upload multipart dan unduh biner. Accept: application/json. |
| Autentikasi | Cookie nadi_session same-origin; ambil GET /api/csrf sebelum mutasi. Kirim X-XSRF-TOKEN hasil decode cookie XSRF-TOKEN. |
| ID dan tanggal | UUID sebagai ID; YYYY-MM-DD untuk tanggal dan YYYY-MM untuk bulan acuan. NIP 18 digit dikirim sebagai string. |
| Versi | Mayoritas route tidak memakai /v1; alias v1 hanya dashboard publik dan daftar pegawai. Belum ada kontrak OpenAPI yang dipelihara. |
| Error validasi | Umumnya {message, errors:{field:[pesan]}}. Error lain mengandung message; frontend merangkai errors untuk pengguna. |
| Cache | API no-store dan noindex. Aset build diberi cache immutable; data pegawai tidak boleh dimasukkan cache CDN publik. |

| HTTP | Makna dan tindakan |
|---|---|
| 401 / 403 | Sesi tidak penuh/berakhir atau hak ditolak. Login ulang atau periksa role/owner. |
| 409 | Revisi, hash, status, duplikat atau urutan berkonflik. Baca kondisi terbaru. |
| 410 | Tautan/unduhan tidak berlaku atau belum tersedia sesuai endpoint. |
| 413 / 419 | Request terlalu besar / CSRF tidak cocok. |
| 422 / 429 | Input/aturan ditolak / rate limit tercapai. |
| 500 / 503 | Error generik / layanan, scanner atau konfigurasi belum tersedia. |

Jangan mengulang mutasi otomatis tanpa memahami idempotensi endpoint. Idempotensi konfirmasi impor tersedia; semua POST lain tidak otomatis mempunyai idempotency key.

**SUMBER IMPLEMENTASI**

routes/web.php · bootstrap/app.php · resources/js/api/client.ts

# API publik, sesi & aktivasi

P = tanpa login internal, tetapi POST tetap memerlukan CSRF. Semua path di bawah relatif terhadap /api.

| Metode / path | Input utama -> hasil |
|---|---|
| GET /csrf | Tidak ada -> {ok:true}, bootstrap cookie CSRF. |
| GET /session | Tidak ada -> {user:{id,name,role}\|null, demo:false}. |
| POST /auth/login | nip, password -> {challenge:true}. Membuat challenge lima menit. |
| POST /auth/totp | code enam digit -> DTO sesi penuh. |
| POST /logout | Tidak ada -> {ok:true}; invalidasi sesi. |
| GET /activation | Header X-Activation-Token -> name, role, login, secret untuk enrollment. Respons ini sensitif. |
| POST /activation | Header token; password, password_confirmation, code -> {ok:true}. |
| POST /auth/recovery | email -> pesan umum; token dikirim ke email terdaftar jika konfigurasi aktif. |
| GET /public/statistics | Query unit, jenis -> DTO agregat. Alias: /v1/public/dashboard. |
| GET /public/units | Tidak ada -> array {id,label} unit aktif terurut. |

## Rate limit

Login/TOTP/aktivasi: 5 per menit per IP serta 30 per jam per identitas input + IP. Recovery: 3 per menit per IP dan 5 per jam per email. Statistik publik: 60 per menit per IP. /public/units tidak dipasangi throttle:public khusus di route saat ini.

> **Jangan log header aktivasi**
> Secret enrollment dikembalikan hanya setelah token valid. Jangan merekam X-Activation-Token, isi respons aktivasi, body password atau URL fragment ke telemetry/screenshot. Token fragment tidak ikut request URL HTTP, lalu dikirim sebagai header oleh client.

Endpoint agregat GET public/visitors serta POST public/visitors/heartbeat adalah pengecualian stateless yang dijelaskan pada halaman berikut. Route akun/pegawai tetap memiliki perlindungan sesi dan CSRF; jangan menyebarkan pengecualian ini ke endpoint privat.

**SUMBER IMPLEMENTASI**

routes/web.php · routes/api_public.php · app/Providers/AppServiceProvider.php · app/Modules/Analytics/Http/DashboardController.php

# API dan frontend statistik pengunjung

Stateless khusus penghitung publik agar heartbeat tidak memperpanjang idle login.

| Endpoint | Kontrak |
|---|---|
| GET /api/public/visitors | Agregat saja; throttle public 60/min/IP, no-store; tidak membuat session cookie dan tidak menambah kunjungan. |
| POST /api/public/visitors/heartbeat | Body kosong/{} tanpa query personal; exact Origin frontend wajib; throttle visitors 120/min/IP, no-store. Balas agregat. |

## Cookie dan perlindungan

nadi_visitor UUID acak, dienkripsi Laravel, Secure produksi, HttpOnly, SameSite Strict, maksimum satu tahun. StartSession, ShareErrorsFromSession dan PreventRequestForgery dikecualikan hanya pada dua route ini. Enkripsi cookie dan security headers tetap aktif. Origin asing/hilang ditolak 403, payload tambahan 422. Browser tidak dapat mengganti Origin ke situs lain.

## Data respons

```
{ "today": 1, "yesterday": 0, "week": 1, "month": 1,
  "year": 1, "total": 1, "online": 1,
  "trackingSince": "2026-10-05", "timezone": "Asia/Makassar",
  "updatedAt": "2026-10-05T08:23:00+08:00",
  "onlineWindowMinutes": 5, "demo": false }
```

Contoh ilustratif. App.vue memasang useVisitorTracking sekali, mengirim tiap 60 detik saat document terlihat, menghindari request tumpang tindih, dan membersihkan timer/listener saat unmount. VisitorStats menampilkan tujuh kartu di portal/Command Center; filter pegawai tidak menyaring pengunjung.

> **Kegagalan dan simulasi**
> Awal data ditampilkan sebagai garis; kegagalan menghasilkan Pembaruan tertunda, bukan angka nol palsu. Simulasi menggunakan angka contoh dengan demo=true. Cookie/account auth tidak dibaca atau diperbarui oleh heartbeat, termasuk ketika admin sedang login.

**SUMBER IMPLEMENTASI**

routes/api_public.php · app/Modules/Analytics/Http/VisitorController.php · resources/js/api/visitors.ts · resources/js/components/VisitorStats.vue

# API pegawai, persetujuan & DUK

A/S = Admin dan Super Admin. S = Super Admin. Semua endpoint membutuhkan sesi penuh.

| Metode / path / akses | Kontrak ringkas |
|---|---|
| GET /employees · A/S | search, unit, type, status, page, per_page (1-100). Hasil {data,total,page,per_page}; alias /v1/internal/employees. |
| GET /dashboard · A/S | Ringkasan internal untuk Command Center. |
| GET /proposals · A/S | 100 usulan terbaru dengan before/changes/revision/status/alasan. |
| POST /proposals · A/S | employeeId opsional, revision, changes, reason 5-1.000 karakter -> DTO usulan (201). |
| POST /proposals/batch · A/S | rows 1-500 berisi employeeId/revision/changes; reason -> {count,ids} (201). |
| POST /proposals/{id}/decide · S | decision APPROVED atau REJECTED, reason -> DTO keputusan. |
| GET /duk · A/S | {rows,order,hash}; order seluruh ID, bukan hanya hasil filter. |
| POST /duk/order · S | order 1-10.000 UUID unik, hash 64 karakter, reason, rows maksimal 500 -> {count,saved:true}. |
| GET /rules · A/S | Penjelasan status DUK/KP/KGB; bukan endpoint pengeditan aturan. |
| GET /audit · A/S | 100 audit terbaru: id, actor, action, subject, createdAt. |

**Perbedaan UI dengan API daftar pegawai**
positionType dan quality dipakai filter frontend/ekspor, tetapi bukan filter tervalidasi GET /employees. Integrasi yang memerlukan jenis jabatan harus memfilter DTO atau menambah kontrak backend dengan tes. Jangan menganggap semua filter UI diterjemahkan ke query SQL.

Tidak tersedia PATCH /employees/{id} atau DELETE pegawai pada route aktif. Semua perubahan isi Master melalui proposal; penonaktifan pegawai memakai status kepegawaian.

**SUMBER IMPLEMENTASI**

routes/api_internal.php · app/Modules/Personnel/Http/EmployeeController.php · app/Modules/Governance/Http/ChangeController.php · app/Modules/Duk/Http/ManualDukController.php

# API impor & ekspor

Hak berkas dibatasi pemilik, bukan hanya UUID yang sulit ditebak.

| Metode / path | Input -> hasil / akses |
|---|---|
| GET /imports | A/S: daftar 100 batch sendiri. |
| POST /imports | A/S: multipart file XLSX -> metadata batch (201). |
| GET /imports/{batch} | Pemilik atau Super Admin baca -> metadata + rows/diff/errors. |
| POST /imports/{batch}/validate | Pemilik: mapping dengan nip wajib -> {status:VALIDATING} (202). |
| POST /imports/{batch}/confirm | Pemilik: previewHash, reason 5-900 karakter, confirmDuplicate opsional -> {count,status:CONFIRMED}. |
| GET /exports | S: 50 job sendiri pada securityVersion kini. Expiry ditampilkan EXPIRED pada daftar. |
| POST /exports | S: kind employees/statistics dan filter -> {id,status:QUEUED} (202). |
| GET /exports/{export} | S + owner + versi akun -> id/status/expiresAt. |
| GET /exports/{export}/download | S + owner + versi akun + READY + belum kedaluwarsa -> file biner; gagal kondisi berkas: 410. |

## Filter ekspor pegawai

unit, type, positionType, status, search, quality boolean dan allStatuses boolean. allStatuses menghapus pembatasan status; tanpa itu default Aktif. kind menentukan format sehingga client tidak memilih format arbitrer.

## Pola integrasi

Unggah -> simpan batch ID -> validasi -> polling GET batch hingga PREVIEW -> tampilkan hasil -> konfirmasi hash yang sama. Untuk laporan: POST exports -> simpan ID -> polling hingga READY -> unduh. Jika UI timeout, periksa riwayat; jangan otomatis membuat permintaan baru.

> **Hak Super Admin bukan hak tulis semua batch**
> Super Admin dapat membaca detail batch orang lain jika mengetahui ID, tetapi validasi/konfirmasi tetap hanya pembuat batch. Daftar impor UI juga hanya menampilkan batch milik sendiri.

**SUMBER IMPLEMENTASI**

app/Modules/Imports/Http/ImportController.php · app/Modules/Imports/Services/ImportService.php · app/Modules/SnapshotsReports/Http/ExportController.php

# API akun, unit & Radar

Kontrol administrasi ditetapkan server; client tidak boleh memilih role arbitrer.

| Metode / path / akses | Input -> hasil |
|---|---|
| GET /accounts · S | Akun ADMIN/SUPER_ADMIN: id, employeeId, name, login, role, status, expiresAt. |
| POST /accounts · S | employeeId UUID; role dilarang -> id, activationPath, expiresAt (201). |
| POST /accounts/{id}/activation · S | Reset/terbitkan tautan Admin -> id, activationPath, expiresAt. |
| POST /accounts/{id}/disable · S | Nonaktifkan akun Admin -> {ok:true}. |
| GET /units · A/S | Unit aktif terurut, sama format daftar unit publik. |
| POST /units · S | label maksimal 150 karakter -> {id,label} (201). |
| PATCH /units/{id} · S | label dan/atau active boolean -> {ok:true}. |
| GET /radar/{kind} · A/S | kind kp atau kgb -> {rows,version}; per baris employee,data,revision,result. |
| POST /radar/{kind}/{id} · A/S | revision, employeeRevision, data -> {ok:true,revision,result}. |

## Validasi Radar yang perlu diperhatikan

• data.process wajib: Belum diusulkan, Diusulkan, Perbaikan, Keputusan terbit, Ditolak. data.reason 5-1.500 karakter.

• Perbaikan membutuhkan correctionDeadline dan processNote. Diusulkan/Keputusan terbit/Ditolak membutuhkan processNote. Tenggat khusus membutuhkan target, acuan, dan tanggal sebelum target.

• Performance: Buruk, Kurang, Cukup, Baik, Sangat Baik. Angka kredit 0-1.000.000. Tanggal SK/TMT KGB tidak boleh di masa depan.

Status akun DTO: ACTIVE, PENDING, EXPIRED, DISABLED. Reset/penonaktifan Super Admin melalui endpoint akun ini ditolak 403.

**SUMBER IMPLEMENTASI**

app/Modules/IdentityAccess/Http/AccountController.php · app/Modules/References/Http/UnitController.php · app/Modules/Radar/Http/RadarController.php

# Contoh payload & kontrak perubahan

Contoh sintetis untuk pengembang; ID dan revisi harus diperoleh dari lingkungan uji.

## Usulan koreksi nama jabatan

```
POST /api/proposals
{
  "employeeId": "11111111-1111-4111-8111-111111111111",
  "revision": 7,
  "changes": { "position": "Analis Perizinan Ahli Muda" },
  "reason": "Koreksi jabatan sesuai dokumen yang diverifikasi"
}
```

Berhasil: HTTP 201 dengan status PENDING. Data Master tetap revision 7 sampai disetujui. Jika revisi sudah berubah, respons 409 dan client harus mengambil data terbaru.

## Keputusan dan permintaan ekspor

```
POST /api/proposals/{id}/decide
{ "decision": "APPROVED", "reason": "Dokumen telah diperiksa" }

POST /api/exports
{ "kind": "employees", "positionType": "Fungsional",
  "allStatuses": true }
```

## Respons error validasi

```
{
  "message": "The given data was invalid.",
  "errors": { "reason": ["Alasan perubahan wajib diisi."] }
}
```

> **Perhatikan envelope endpoint**
> Tidak semua GET mengembalikan {data:...}. employees memakai envelope pagination, duk/radar memakai rows, sedangkan accounts/proposals/units/audit berupa array. Jangan menggunakan satu parser pagination untuk seluruh API.

Contoh pesan di atas menggambarkan struktur; bahasa/pesan validator dapat berbeda. Buat contract test berdasarkan field dan status HTTP, bukan hanya kalimat error.

**SUMBER IMPLEMENTASI**

routes/api_internal.php · resources/js/api/client.ts · app/Modules/Governance/Http/ChangeController.php

# Keamanan: kontrol 1-10

Ringkasan kontrol yang tercatat pada audit 28 September 2026, disertai lokasi implementasi.

| No. / pemeriksaan | Kontrol dan pemeliharaan |
|---|---|
| 1. API key | Kunci backend privat; tidak dibundel ke frontend. Inventarisasi layanan/kunci baru sebelum menambah integrasi. |
| 2. ENV tidak publik | Git/Docker ignore dan Nginx deny. app.env 0600, direktori .deploy 0700. Jangan menaruh secret pada variabel VITE_*. |
| 3. Hardcoded secret | Tidak ditemukan secret nyata pada pemindaian baseline. Placeholder/fixture uji tidak boleh dipakai produksi. |
| 4. Git secret | Gitleaks dan pemeriksaan blob tercatat bersih. Pemindaian harus diulang untuk commit/rilis baru. |
| 5. Debug OFF | APP_ENV=production, APP_DEBUG=false; PHP display_errors off dan expose_php off. |
| 6. Error tidak bocor | API 500 generik dan no-store; log detail hanya untuk operator. Jangan membagikan stack trace mentah. |
| 7. Validasi input | Allowlist, enum, regex NIP, panjang, tanggal, referensi, revision/hash. |
| 8. Sanitasi/output | Vue/Blade escape; folder Drive HTTPS dibatasi; XLSX menolak konten aktif; ekspor string eksplisit. |
| 9. SQL injection | Eloquent/binding; raw SQL ekspresi tetap/placeholder. Semua query baru wajib ditinjau. |
| 10. XSS | CSP self, object-src none, nosniff, frame DENY; inline style masih diizinkan, inline script tidak. |

**Ruang lingkup hasil audit**
Lulus pemeriksaan pada satu baseline bukan jaminan bebas seluruh kerentanan. Dokumen ini merangkum bukti historis proyek; pentest independen, audit dependency baru dan uji proxy publik tetap pekerjaan tersendiri.

Sumber kebocoran operasional yang harus dijaga: body request aktivasi, payload jobs/failed_jobs, audit metadata, log mail, dump DB, screenshot internal dan arsip deployment.

**SUMBER IMPLEMENTASI**
docs/operations/SECURITY_REVIEW_2026-09-28.md · infra/nginx/security-headers.conf · .gitignore · .dockerignore · bootstrap/app.php

# Keamanan: kontrol 11-20

Pemindaian unggahan dan sesi harus tetap berjalan saat sistem dibuka untuk umum.

| No. / pemeriksaan | Kontrol dan batas |
|---|---|
| 11. Server-side auth | RequireFullSession memeriksa sesi penuh + TOTP + akun aktif + security_version. |
| 12. Akses pengguna | Role, ownership batch/ekspor dan versi keamanan diperiksa server. Admin belum dibatasi per unit. |
| 13. Role admin | Super Admin saja kelola Admin; request role arbitrer ditolak; akun Super Admin dilindungi pada menu akun. |
| 14. DB privat | PostgreSQL hanya network internal; tidak ada published port. |
| 15. DB least privilege | nadi_runtime bukan owner/superuser/DDL; hak audit/snapshot dibatasi; grant diulang setelah migrasi. |
| 16. Password hash | Hash Laravel; secret TOTP terenkripsi memakai kunci terpisah. |
| 17. Session | Secure, HttpOnly, SameSite Strict, terenkripsi; idle 30 menit/absolut 8 jam; CSRF dan rate limiter. |
| 18. Reset aman | Token acak/hash, expiry dan sekali pakai, MFA baru; SMTP pemulihan produksi aktif dan telah diuji. |
| 19. Batas upload | XLSX 5 MiB; Nginx request 6 MiB; satu sheet/1.000 baris/50 kolom/2.000 ZIP entries/25 MiB terurai. |
| 20. Antivirus | ClamAV INSTREAM sebelum parser; infeksi 422, scanner gagal 503. Production tidak boleh bypass scan. |

Penolakan struktur XLSX meliputi ZIP traversal, entry ganda/terenkripsi, external relationships, DTD/entity, makro, embedded object dan formula. Scanner bersih bukan alasan melewati validasi struktur.

> **Pisahkan kewenangan operator**
> Akses root/grup Docker dapat membaca data container. Batasi personel dan serah terima kunci melalui jalur privat. Grant SQL runtime tidak melindungi data dari operator host yang sepenuhnya berwenang.

**SUMBER IMPLEMENTASI**

app/Modules/Imports/Services/UploadScanner.php · app/Modules/Imports/Services/ImportService.php · infra/docker/runtime-grants.sql · config/session.php

# Konfigurasi & pengelolaan secret

Nilai rahasia tidak dicantumkan. .env.example adalah daftar struktur, bukan konfigurasi siap produksi.

| Variabel / kelompok | Fungsi dan nilai yang diharapkan |
|---|---|
| APP_ENV / APP_DEBUG | production / false pada VPS. APP_TIMEZONE=Asia/Makassar. |
| APP_KEY / NADI_TOTP_KEY | Dua kunci berbeda. TOTP tepat 32 byte base64. Cadangkan secara terenkripsi terpisah; jangan regenerate pada upgrade. |
| APP_URL / NADI_FRONTEND_URL | URL pengguna dan tautan aktivasi; harus HTTPS dengan host publik sama saat launch. |
| DB_* | Koneksi PostgreSQL dengan user runtime. Password owner tidak dimasukkan ke env aplikasi. |
| SESSION_* | Database, idle 30 menit, Secure true produksi. Encrypt dan SameSite dipatok oleh config/session.php; bukan semua nama ENV example dibaca dinamis. |
| QUEUE_CONNECTION / CACHE_STORE | database untuk runtime. Worker harus memakai konfigurasi/image yang sama dengan app. |
| NADI_UPLOAD_SCAN_ENABLED / CLAMAV_* | true produksi; host antivirus, port 3310. Timeout scan 30 detik di config. |
| NADI_TRUSTED_PROXIES | IP proxy yang benar-benar dipercaya; jangan wildcard. |
| MAIL_* / NADI_RECOVERY_MAIL_ENABLED | Transport, pengirim dan kredensial SMTP privat; aktifkan setelah uji pengiriman. |
| NADI_PRODUCTION_READY | Gate pemeriksaan peluncuran, bukan firewall. |
| NADI_IMPORT_RETENTION_DAYS | Default 14; metadata expiry, belum purge/enforcement lengkap. |

NADI_PUBLIC_RELEASE_ENABLED masih ada untuk jalur lama dan tidak menutup statistik aktif. NADI_INITIAL_RECOVERY_NIP/EMAIL hanya provisioning migrasi satu kali, bukan sinkronisasi konfigurasi akun.

**Rotasi harus direncanakan**
Rotasi DB/SMTP melibatkan perubahan privat dan restart/recreate service. Rotasi APP_KEY/TOTP membutuhkan analisis ciphertext dan migrasi kunci; jangan menjalankan key:generate pada instalasi yang memiliki akun aktif.

**SUMBER IMPLEMENTASI**
.env.example · config/nadi.php · config/session.php · config/trustedproxy.php · config/uploads.php

# Menyiapkan pengembangan lokal

Lakukan pada clone dan database development terpisah, bukan database operasional.

## Prasyarat dan instalasi baru

Node 24, Composer 2, PHP 8.4 dan PostgreSQL 16. Ekstensi PHP: pdo_pgsql, mbstring, openssl, xml, ctype, json, bcmath, intl, zip, gd dan pcntl untuk worker. Jalankan perintah dari root repository.

```
npm ci
composer install
# Hanya instalasi BARU tanpa .env:
cp .env.example .env
php artisan key:generate
```

Isi DB development privat dan NADI_TOTP_KEY acak yang berbeda. Siapkan role owner untuk migrasi, runtime untuk aplikasi; jalankan php artisan migrate menggunakan owner. Konfigurasi .env lama tidak boleh ditimpa. Bootstrap akun baru melalui nadi:create-admin dengan enrollment oleh pemilik.

## Tiga proses untuk backend asli lokal

```
php artisan serve --host=127.0.0.1 --port=8000
php artisan queue:work --tries=3 --timeout=90
npm run dev:backend
```

Jalankan setiap proses pada terminal berbeda. Browser http://127.0.0.1:5173; Vite meneruskan /api ke Laravel 8000. Untuk pengujian HTTPS/produksi gunakan stack Docker, bukan mengekspos Vite.

## Simulasi terpisah

```
npm run dev:demo
# Buka http://127.0.0.1:5176
```

> **Data asli tidak ikut clone**
> Demo memakai fixture dan .runtime/demo-state.json; bukan sakelar menuju DB asli. Untuk lingkungan baru gunakan fixture sintetis. Memulihkan data nyata membutuhkan arsip DB/files/kunci yang diserahkan melalui jalur privat.

**SUMBER IMPLEMENTASI**

docs/operations/SETUP.md · package.json · vite.config.ts · routes/console.php

# Pengujian & penerimaan perubahan

Bukti rilis 5 Oktober 2026; suite selalu memakai PostgreSQL testing terpisah.

```
npm test
npm run build
npm run check:php
# Database testing, bukan produksi:
APP_ENV=testing DB_DATABASE=nadi_testing php artisan migrate --force
php vendor/bin/phpunit
```

| Verifikasi | Hasil / cakupan |
|---|---|
| Backend | 85 tes / 424 assertion lulus; fitur pengunjung 8 tes / 49 assertion termasuk isolasi sesi. |
| Frontend dan sintaks | 17 Vitest lulus; produksi build lulus; 95 file PHP tanpa kesalahan sintaks. Chunk ExcelJS tetap besar dan dimuat dinamis. |
| Domain produksi | 26 pemeriksaan anonim dan 11 pemeriksaan endpoint pengunjung lulus. |
| Runtime | 13 preflight lulus, 21 monitor sehat; fingerprint inti pegawai/akun/audit identik sebelum dan sesudah rilis. |
| Operasi | Backup data/project diverifikasi melalui baca ulang pada 5 Oktober; restore DB terisolasi dan verifikasi arsip project pada 30 September. |

## Regresi minimum

Login/TOTP/logout; Admin ditolak dari keputusan/akun/ekspor; self-approval Super Admin; konflik revisi/hash; DUK dan Excel seurut; impor formula ditolak; umur/masa kerja pada batas tanggal; Radar setelah perubahan Master; owner/expiry unduhan; DTO publik tanpa identitas; heartbeat tidak memperpanjang idle login.

> **Batas bukti**
> Suite tidak dijalankan ulang hanya karena buku diterbitkan. Belum ada bukti stress beban/konkurensi menyeluruh, audit aksesibilitas lengkap, SLA atau RTO pemulihan aplikasi penuh yang disahkan. Audit dependency/security 28 September tetap bukti bertanggal.

**SUMBER IMPLEMENTASI**

docs/VALIDASI.md · tests/Laravel/VisitorStatisticsTest.php · phpunit.xml · infra/monitor/public-check.py

# VPS privat: akses & pemeriksaan

Domain HTTPS adalah jalur pengguna; SSH dan endpoint privat hanya untuk operator.

| Identitas | Kondisi |
|---|---|
| Host / sistem | VPS Ubuntu 24.04 LTS; inventaris akses pada runbook VPS. |
| Direktori / Compose | /home/anggauser/nadi-asn / nadi-asn |
| Publik / endpoint host | Domain HTTPS utama; 127.0.0.1:18443 menuju web:8443. |
| Runtime | Enam service. Domain melalui NPM; SMTP pemulihan aktif. |
| Konfigurasi privat | .deploy/app.env; db-owner-password; TLS, monitor dan OAuth backup. Tidak masuk Git. |
| Data utama | Database VPS; lokal lama read-only dan tidak tersinkron otomatis. |

## Pemeriksaan dari VPS

```
cd /home/anggauser/nadi-asn
docker compose -f infra/compose.yaml \
  -f infra/domain/compose.proxy.yaml ps
docker exec nadi-asn-app-1 php artisan nadi:preflight
python3 -B infra/monitor/check.py
```

## Jalur cadangan

Port-forward SSH ke localhost:18443 hanya bila domain bermasalah dan operator mempunyai akses. Verifikasi sertifikat internal atau pasang trust CA melalui kebijakan kantor; gunakan domain untuk pengguna umum. Detail SSH ada pada VPS_PRIVATE.md.

> **Jaga isolasi**
> Gunakan kedua file Compose ketika membuat ulang web. Jangan menjalankan down -v, menginisialisasi ulang database, memulihkan dump lama atau me-restart seluruh container kantor untuk memperbaiki tampilan. Akses Docker/root setara kewenangan membaca rahasia.

**SUMBER IMPLEMENTASI**

infra/compose.yaml · infra/domain/compose.proxy.yaml · docs/operations/VPS_PRIVATE.md

# Runbook rilis & migrasi

Bangun rilis yang dapat dibalik sebelum mengganti service; migrasi memakai role owner.

| Tahap | Tindakan |
|---|---|
| 1. Bekukan rilis | Catat commit/lockfile, inventaris container, fingerprint dan image cadangan terverifikasi. |
| 2. Cadangkan | DB, file privat, konfigurasi/kunci dan source; periksa unggahan serta kemampuan pemulihan. |
| 3. Tentukan dampak | Koordinasikan jendela bila penulisan/skema memerlukan; migrasi tambahan yang kompatibel dapat mengurangi downtime. |
| 4. Bangun | Build hanya app/web NADI ASN; periksa .dockerignore dan kapasitas. Jangan sentuh aplikasi kantor lain. |
| 5. Migrasi | One-off owner melalui secret privat. Runtime tidak memiliki DDL. Pertahankan izin 0600 pada secret. |
| 6. Grant | Terapkan runtime-grants.sql sesudah migrasi sebagai owner. Jangan memasukkan kredensial owner ke app.env. |
| 7. Ganti service | Kedua file Compose; up --no-build --no-deps untuk app, worker, scheduler, web. DB/antivirus tidak perlu dibuat ulang pada rilis biasa. |
| 8. Periksa | Health, preflight, mode asli, domain/auth, fingerprint, monitor dan browser. Simpan hasil. |

**Container migrasi dengan cap_drop ALL**
UID 0 tanpa kemampuan DAC override tidak selalu dapat membaca secret milik host UID lain atau menulis cache www-data. Gunakan UID yang sesuai kepemilikan secret dan tmpfs cache sementara yang writable. Jangan chmod secret 0644 atau memberi owner pada runtime.

Rollback kode tidak memulihkan data. Image lama harus kompatibel dengan skema kini. Jangan migrate:rollback atau restore dump sebagai langkah rutin; beberapa migrasi menjaga histori dan menolak rollback.

**SUMBER IMPLEMENTASI**
infra/docker/Dockerfile · infra/compose.yaml · infra/docker/runtime-grants.sql · docs/operations/VISITOR_STATISTICS.md

# Domain, HTTPS & SMTP

Domain publik, sertifikat dan pemulihan email aktif sejak 30 September 2026.

## DNS dan batas proxy

Hostinger mengarahkan A apex ke VPS dan CNAME www ke domain utama. HTTP dan HTTPS www dialihkan ke HTTPS apex. NPM memakai konfigurasi khusus /data/nginx/nadi/domain.conf; host ini tidak muncul sebagai Proxy Host pada UI. Jangan membuat host kedua tanpa migrasi konfigurasi.

## Dua lapisan TLS

Sertifikat publik Let's Encrypt mencakup apex/www dan diperpanjang cron dua kali sehari melalui namespace nadi-asn. TLS upstream web diverifikasi terhadap CA privat dan nama localhost. Hanya web berada di network proxy; DB/app tetap terisolasi.

```
curl -I https://nadiasndpmptspsulteng.online/
docker exec npm nginx -t
# Operator: periksa crontab dan renew.log, bukan private key.
```

## Email pemulihan

SMTP Gmail dikonfigurasi privat; penerima pemulihan tersimpan di users.recovery_email dan tidak selalu sama dengan pengirim. Sandi aplikasi tidak masuk dokumen atau Git. Pemilik mengonfirmasi pemulihan end-to-end pada 30 September.

APP_URL dan NADI_FRONTEND_URL memakai domain HTTPS yang sama. Perubahan env_file memerlukan recreate app/worker/scheduler; restart saja tidak selalu membaca env baru. Uji email hanya dengan koordinasi pemilik karena tautan baru menggantikan tautan lama.

> **Pemulihan kegagalan**
> Periksa transport, sender, jaringan, flag dan kredensial privat. Kegagalan SMTP membatalkan token permintaan baru; password/OTP yang aktif tetap berlaku. Jangan menonaktifkan TLS/CSRF untuk memperbaiki koneksi.

**SUMBER IMPLEMENTASI**

infra/domain/renew-certificate.sh · infra/domain/nadi-domain-public.conf · config/mail.php · docs/operations/DOMAIN_2026-09-30.md

# Pemantauan & tugas rutin

Monitor host lima menit aktif; gangguan dua kali berturut-turut memicu email.

| Cakupan | Pemeriksaan / tindakan |
|---|---|
| 21 pemeriksaan | Enam container, health/session HTTPS, mode asli, DB, scheduler, antrean/jobs, gate/debug/cookie, disk, masa berlaku TLS publik/internal dan umur backup. |
| Transisi insiden | Dua gagal berurutan mengirim email gangguan; satu sehat mengirim email pulih. Kondisi sama tidak mengirim ulang. Pengiriman gagal dicoba lagi. |
| Eksekusi / privasi | Cron anggauser menjalankan infra/monitor/check.py. Config/state/log privat dalam .deploy/monitor; email tidak memuat secret atau identitas pegawai. |
| Cadangan | Monitor memeriksa usia last-success data/project. Kegagalan upload sesaat tidak langsung mendapat alarm tersendiri. |
| Antrean dan storage | Periksa umur job, failed_jobs, log, kapasitas disk/inode dan private_files. Upload scanner fail-closed. |

```
cd /home/anggauser/nadi-asn
python3 -B infra/monitor/check.py
cat .deploy/monitor/status.json
tail -n 30 .deploy/monitor/monitor.log
```

**Batas pemantauan**
Monitor berada pada VPS yang sama, tidak me-restart service. VPS mati total/cron berhenti/jaringan SMTP terputus tidak dapat dilaporkan dari host ini; monitor eksternal belum dipasang. HTTP sehat tidak membuktikan seluruh alur pengguna sehat.

Log Docker dibatasi 10 MB x 3 per container. Laravel LOG_CHANNEL=single tidak ikut rotasi Docker; retensi/rotasi log aplikasi perlu kebijakan terpisah. Jangan memakai pembaruan online pengunjung sebagai bukti sesi login atau worker tetap sehat.

**SUMBER IMPLEMENTASI**
infra/monitor/check.py · docs/operations/MONITORING.md · infra/compose.yaml · routes/console.php

# Strategi backup & retensi

Dua jalur backup terenkripsi Google Drive aktif sesuai kebijakan pengelola.

| Jalur | Isi / jadwal |
|---|---|
| Data operasional | vps-backup.sh: seluruh DB termasuk pengunjung, private_files dan recovery kit; setiap 14 hari 02.00 WITA. Folder NADI-ASN-Backup. |
| Project lengkap | project-backup.sh: seluruh pohon VPS, source/assets/docs/PDF/lockfile/infra/config privat dan history bundle; tiga bulan kalender 03.00 WITA. Folder NADI-ASN-Project-Backup. |
| Pengecualian project | DB/volume privat dipulihkan dari backup data. Docker image dibangun ulang. Engine/snapshot/token OAuth backup dan kunci dekripsi tidak ikut project. |
| Enkripsi / integritas | age stream tanpa dump plaintext pada VPS; manifest dan SHA256SUMS. Copy, kemudian check --download seluruh file sebelum replacement. |
| Kunci / retensi | Private age identity di luar VPS dan akun Drive. Backup lama diganti sesudah verifikasi; Drive Trash tidak dikosongkan. |

## Jadwal dan marker

Cron memeriksa jatuh tempo harian; interval data bukan */14 tanggal bulan dan project bukan 90 hari. Marker last-success/project-last-success diubah hanya setelah sukses, termasuk backup manual. Snapshot 5 Oktober terverifikasi lima file data dan tiga file project.

> **RPO dan snapshot**
> Kebijakan 14 hari menggantikan target awal PRD enam jam; kehilangan transaksi sejak backup terakhir tetap mungkin. Dump DB konsisten, tetapi arsip volume diambil setelah dump sehingga bukan snapshot atomik lintas volume. Pengujian restore DB/arsip tidak menetapkan RTO aplikasi penuh.

Kuota API Google Drive sempat menolak upload 5 Oktober; retry berhasil dan cadangan lama tetap aman. Token OAuth privat; koneksi aktif belum memakai client khusus kantor. Siapkan migrasi koneksi lewat otorisasi pemilik agar tidak bergantung pada client bersama.

**SUMBER IMPLEMENTASI**

infra/backup/vps-backup.sh · infra/backup/project-backup.sh · infra/backup/policy.py · docs/operations/BACKUP_GOOGLE_DRIVE.md

# Runbook pemulihan bencana

Lakukan restore drill pada lingkungan terisolasi sebelum prosedur ini diperlukan dalam insiden nyata.

| Tahap | Keluaran yang harus diperiksa |
|---|---|
| 1. Tetapkan recovery point | Pilih backup sebelum kerusakan; identifikasi transaksi yang mungkin hilang dan catat keputusan pemulihan. |
| 2. Verifikasi arsip | Periksa checksum file terenkripsi, sumber/akses, kunci dekripsi dan kelengkapan DB/files/config. |
| 3. Siapkan lingkungan kosong | Gunakan project/volume/DB terpisah, commit kompatibel dan network privat. Nonaktifkan pengiriman email/pengguna eksternal selama drill. |
| 4. Pulihkan DB dan file | Decrypt ke ruang privat, pg_restore dengan role owner ke DB tujuan. Pulihkan private_files pada path/izin yang tepat. |
| 5. Pulihkan kunci dan grant | Gunakan APP_KEY/TOTP key yang cocok dengan data; terapkan runtime-grants.sql. Jangan generate ulang kunci lama. |
| 6. Bersihkan state sementara | Tinjau sesi, challenge/token, cache dan antrean lama sebelum layanan aktif. Jangan replay job mutasi tanpa rekonsiliasi. |
| 7. Verifikasi teknis | Migrasi sesuai, constraint/trigger ada, row count/checksum sesuai, login/TOTP, urutan DUK, Radar dan laporan bekerja. |
| 8. UAT dan cutover | Pemilik data memeriksa sampel. Catat RPO/RTO aktual, buka akses bertahap, pantau dan simpan laporan drill. |

## Kriteria berhasil

Tidak cukup pg_restore selesai tanpa error. Operator harus membuktikan akun bisa digunakan dengan kunci benar, data/riwayat tetap konsisten, ownership berkas berlaku, dan ekspor baru berhasil. Bandingkan hitungan dengan manifest backup, bukan angka pegawai yang ditulis statis di dokumen.

> **Jangan menimpa sumber yang sedang sehat**
> Recovery tidak dijalankan ke DB produksi sebagai percobaan. Setelah validasi, perpindahan endpoint dilakukan dalam jendela yang terkoordinasi; simpan salinan kondisi sebelum cutover untuk investigasi.

**SUMBER IMPLEMENTASI**

docs/operations/SETUP.md · docs/operations/VPS_PRIVATE.md · infra/docker/runtime-grants.sql

# Troubleshooting & respons insiden

Urutan penanganan: tentukan dampak, kumpulkan bukti minimum, pulihkan terarah, lalu verifikasi.

| Gejala | Pemeriksaan / tindakan |
|---|---|
| Login berulang / 419 | Periksa URL/scheme/proxy, cookie Secure, domain, CSRF baru, waktu dan cache browser. Jangan mematikan CSRF sebagai perbaikan. |
| OTP selalu gagal | Jam perangkat, secret/kunci TOTP yang cocok, replay last_totp_step dan challenge expiry. Jangan menulis secret ke log. |
| Impor 503 | ClamAV health, signature, koneksi internal dan timeout. Pulihkan scanner; jangan mem-bypass production scan. |
| Import VALIDATING / export QUEUED | Periksa worker, failed_jobs dan image/env. UI timeout tidak berarti job gagal. Retry hanya setelah penyebab dipahami. |
| Perubahan 409 | Data atau order sudah berubah. Muat ulang dan ajukan ulang; jangan mengubah revision/hash secara manual. |
| Ekspor 403 / 410 | Owner, security_version, expiry dan file privat. Buat laporan baru jika tidak lagi berlaku. |
| Unit tidak bisa nonaktif | Periksa assignment OFFICIAL termasuk historis; jangan menghapus bukti histori untuk melewati aturan. |
| API 500 / 502 | Log privat app/web, koneksi FPM/DB, migrasi, izin storage, kapasitas dan OOM. |
| Email 503 | Flag, transport, sender, kredensial, jaringan keluar dan env setelah recreate. Jangan log body/tautan. |

**Dugaan kebocoran atau pengambilalihan**
Batasi akses komponen terdampak, pertahankan audit/log dan catat waktu. Cabut akun/sesi atau rotasi kredensial yang relevan melalui prosedur terverifikasi. Koordinasikan pemilik sistem/tim keamanan sebelum restore atau menghapus bukti.

**Akses Super Admin hilang**
Gunakan pemulihan email yang telah aktif dan teruji. Bila SMTP bermasalah, pulihkan transport terlebih dahulu dengan pengelola tepercaya. Belum ada fitur break-glass siap pakai; jangan mengubah APP_ENV produksi menjadi local agar perintah provisioning dapat berjalan.

**SUMBER IMPLEMENTASI**
docs/operations/VPS_PRIVATE.md · app/Modules/IdentityAccess/Http/RecoveryController.php · routes/personnel_setup.php · config/queue.php

# Kapasitas, batas & backlog teknis

Fitur peluncuran sudah aktif; batas dan pemeliharaan berikut belum menjadi SLA.

| Prioritas | Pekerjaan / alasan |
|---|---|
| Peluncuran selesai | Domain/TLS, SMTP teruji, offsite terenkripsi, restore DB terisolasi, monitor host, UAT pemilik dan VPS sumber utama. Monitor eksternal belum ada. |
| Operasi berkelanjutan | Retensi/purge imports/exports/log/queue; audit dependency/image; pemilik kunci, prosedur recovery dan patch terjadwal. |
| Integritas layanan | Enforce expiry impor sesuai kebijakan; review penonaktifan unit terhadap histori OFFICIAL; rekonsiliasi login saat NIP berubah. |
| Skalabilitas | Dorong filter/proyeksi/pagination ke query terukur; hindari pemuatan seluruh data berulang pada statistik/DUK/Radar/ekspor. |
| Pengalaman frontend | Tinjau ukuran chunk ExcelJS; uji tabel besar, keyboard/screen reader dan kontras seluruh tema. |
| Model histori | Resolver identitas future-effective/bitemporal lengkap, bila kebutuhan organisasi memang memerlukannya. |
| Integrasi / rules | Outbox consumer, notifikasi terkelola, kontrak OpenAPI dan rule governance UI belum tersedia. |
| Pembersihan kode | Review dan deprecate jalur DUK publikasi lama tanpa merusak arsip; jangan menghapus migrasi historis. |

Belum ada angka throughput, pengguna serentak atau SLA yang dibuktikan. Lakukan load test di staging dengan pola baca, impor 1.000 baris, laporan dan update bersamaan sebelum menetapkan kapasitas layanan.

> **Perubahan aturan wajib terlacak**
> Jika instansi mengubah aturan KP/KGB, simpan dokumen acuan, contoh kasus, versi kalkulator, tes batas tanggal/jenjang/kinerja dan keputusan migrasi pemeriksaan yang sudah tersimpan. Jangan hanya mengubah teks UI.

**SUMBER IMPLEMENTASI**

app/Modules/Personnel/Http/EmployeeController.php · app/Modules/References/Http/UnitController.php · docs/STATUS_IMPLEMENTASI.md · docs/operations/SECURITY_REVIEW_2026-09-28.md

# Checklist serah terima tim IT

Gunakan checklist ini untuk menetapkan penanggung jawab; nama personel diisi oleh instansi.

| Item | Bukti yang diserahkan |
|---|---|
| Pemilik produk/data | Penanggung jawab kebutuhan, persetujuan aturan dan UAT; daftar Admin aktif. |
| Repository dan rilis | Akses GitHub privat, branch utama, commit/tag operasional, lockfile dan cara build. |
| Akses infrastruktur | Inventaris VPS, SSH keys, hak Docker, direktori, service, volume dan reverse proxy melalui jalur privat. |
| Konfigurasi / secret | Daftar pemilik kunci, lokasi secret store, prosedur rotasi dan recovery; bukan salinan secret di buku. |
| Database dan data | Versi skema, owner/runtime role, manifest data, sumber utama lokal/VPS dan prosedur koreksi. |
| Backup/recovery | Remote offsite, jadwal/retensi, pemilik kunci dekripsi, hasil drill dan RPO/RTO aktual. |
| Operasi | Monitor, alarm, log, restart, patch window, runbook insiden dan daftar kontak eskalasi. |
| Pengujian | Hasil otomatis per commit, UAT, kasus regresi dan daftar batas yang diterima. |
| Dokumentasi | Buku pengguna, dokumen teknis ini, perubahan aturan, security review dan catatan deployment. |

## Penerimaan yang disarankan

Tim penerima mampu membangun clone, menjalankan mode sintetis, menjelaskan alur proposal, menjalankan tes di DB terpisah, membaca log, memulihkan backup staging dan menemukan konfigurasi tanpa meminta password lewat chat.

> **Status penerimaan**
> Dokumen ini belum menjadi berita acara serah terima yang ditandatangani. Tanggal penerimaan, nama pemberi/penerima, batas layanan, kontak eskalasi dan jadwal piket harus disepakati organisasi.

**SUMBER IMPLEMENTASI**

docs/operations/SETUP.md · docs/operations/VPS_PRIVATE.md · docs/user/PANDUAN.md

# Indeks sumber & istilah teknis

Semua path relatif terhadap root repository; source of truth adalah baseline kode yang dicatat di awal.

| Pertanyaan tim penerus | Sumber yang dibaca |
|---|---|
| Bagaimana route dan sesi bekerja? | routes/web.php; routes/api_internal.php; bootstrap/app.php; IdentityAccess/. |
| Bagaimana data disahkan? | Governance/Services/ChangeService.php; Personnel/Services/EmployeeProjection.php; database/migrations/. |
| Bagaimana DUK/Radar dihitung? | Duk/Http/ManualDukController.php; Radar/Services/RadarCalculator.php; NADI-ASN-Rules-KP dan KGB.md. |
| Bagaimana file diamankan? | Imports/Services/ImportService.php dan UploadScanner.php; SnapshotsReports/Http/ExportController.php. |
| Bagaimana menjalankan dan memulihkan? | infra/; docs/operations/SETUP.md; VPS_PRIVATE.md; SECURITY_REVIEW_2026-09-28.md. |
| Apa yang sudah diuji? | tests/; docs/VALIDASI.md; security review terbaru. |

## Istilah

**DTO:** bentuk data yang sengaja dikirim ke client. **Revision:** nomor versi untuk mencegah penimpaan perubahan. **Canonical hash:** sidik isi deterministik, bukan enkripsi. **Fail-closed:** operasi ditolak ketika prasyarat keamanan tidak tersedia.

**Worker:** pemroses antrean. **Scheduler:** pelaksana tugas berjadwal. **Outbox:** catatan event dalam transaksi untuk diproses kemudian. **RPO:** batas kehilangan data berdasarkan waktu. **RTO:** target waktu pemulihan layanan. **Cutover:** perpindahan terencana ke sumber/lingkungan operasional baru.

> **Cara memperbarui dokumen**
> Ubah content.py pada docs/architecture/technical-handbook, lalu jalankan build.py dengan Python yang memiliki ReportLab dan Pillow. Hasil Markdown dan PDF dibuat ulang bersama; periksa semua halaman PDF sebelum menerbitkan versi baru.

Tanggal/hasil validasi lama tidak boleh diganti menjadi “lulus terbaru” tanpa pengujian baru. Simpan catatan perubahan dokumentasi bersama perubahan sistem yang mendasarinya.

**SUMBER IMPLEMENTASI**

docs/architecture/technical-handbook/content.py · docs/architecture/technical-handbook/build.py